



Certificate of Cloud Security Knowledge (CCSK) Bootcamp

Michael J Shannon

CISSP, CCSP, CCSK, CCZT

CompTIA SecurityX

AWS Security-Specialty

ITIL4 Managing Professional

**Class will begin at 10:00
Central Standard Time**

The Certificate of Cloud Security Knowledge (CCSK)

- According to the Cloud Security Alliance (CSA): “The Certificate of Cloud Security Knowledge (CCSK) certificate is widely recognized as the standard of expertise for cloud security and gives you a cohesive and vendor-neutral understanding of how to secure data in the cloud
- The CCSK credential is the foundation to prepare you to earn additional cloud credentials specific to certain vendors or job functions.”

The Certificate of Cloud Security Knowledge (CCSK)

- The CCSK exam is open-book and online. It contains 60 multiple-choice questions selected randomly from a larger pool
- You must complete it in 120 minutes.
- The minimum passing score is 80%.
- Purchase of the Exam and Chatbot costs \$445 and provides you with two test attempts, which you will have 2 years to use.

The Certificate of Cloud Security Knowledge (CCSK)

- Enter Save (after selecting answer)
- ← Previous Question (does not save answer)
- → Next Question (does not save answer)
- **Save and Mark for Review** will both save your answer and be graded if you submit your exam early or run out of time
- Marking a question for review is a convenience for going through the exam quickly and returning to questions you are unsure on
- Warning: If you do not click Save/Mark for review, your answers will not be saved

CCSK Bootcamp Day 1

1. Cloud Computing Concepts & Architectures
2. Cloud Governance and Strategies
3. Risk, Audit and Compliance
4. Organization Management
5. Identity and Access Management
6. Security Monitoring



Cloud Computing Value Propositions

- **Agility** enables the speed of implementation of services, experimentation, and innovation
- **Elasticity** offers the ability to scale and de-provision on demand enhancing the ability to eliminate wasted capacity
- **Flexibility** means that the cloud provider presents a broad set of products with low to no cost to entry
- **Security and governance** is a top priority as CSPs have acquired many certifications and helps organizations get certified
 - The shared responsibility model is an agreement where the cloud provider is responsible for the infrastructure whereas the customer is responsible for everything else

Cloud Computing Value Propositions

- Trade fixed capital expenses for variable expenses
- Gain value from massive economies of scale
- Stop trying to predict capacity
- Enhance speed and agility
- Cease spending money operating and maintaining on-site data centers
- Go global in a matter of minutes or hours

Cloud Computing Characteristics

- **Broad network access** is a cloud feature that allows users to conveniently access physical and virtual resources from wherever they are using a wide variety of network-accessible devices such as cell phones, tablets, laptops, and workstations
- **Measured service** is a cloud feature where service use can be monitored, controlled, reported, and billed on metered, pay-for-use basis ... an important feature that helps optimize and validate cloud services

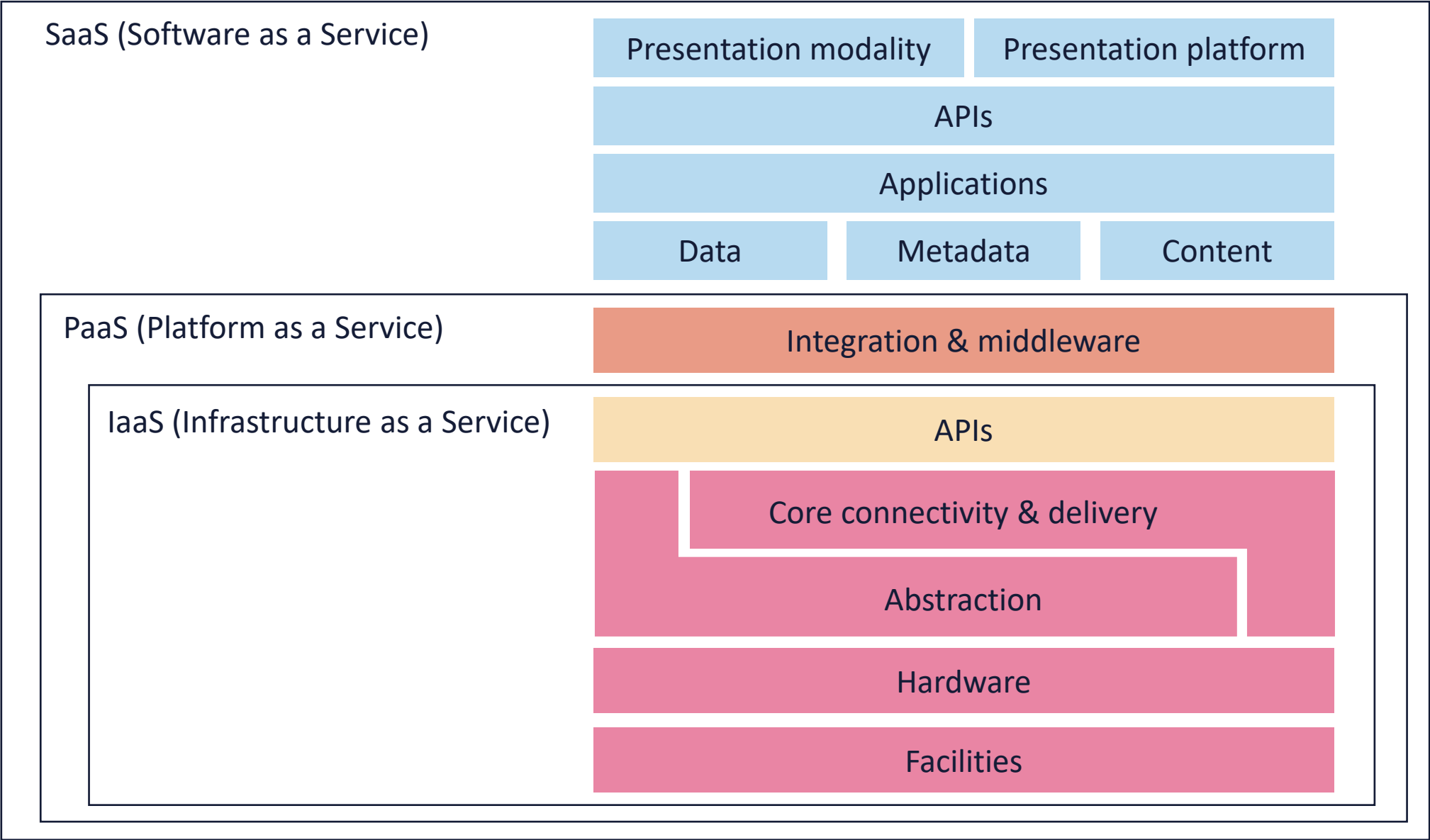
Cloud Computing Characteristics

- **Multi-tenancy** is a function where physical or virtual resources are allocated in a way that isolates guests and their data from one another
 - Typically – within the context of multi-tenancy – the group of users that form a tenant will all belong to the same cloud service
- There may be cases where the group of users involves multiple service customers e.g., public cloud and community cloud deployments

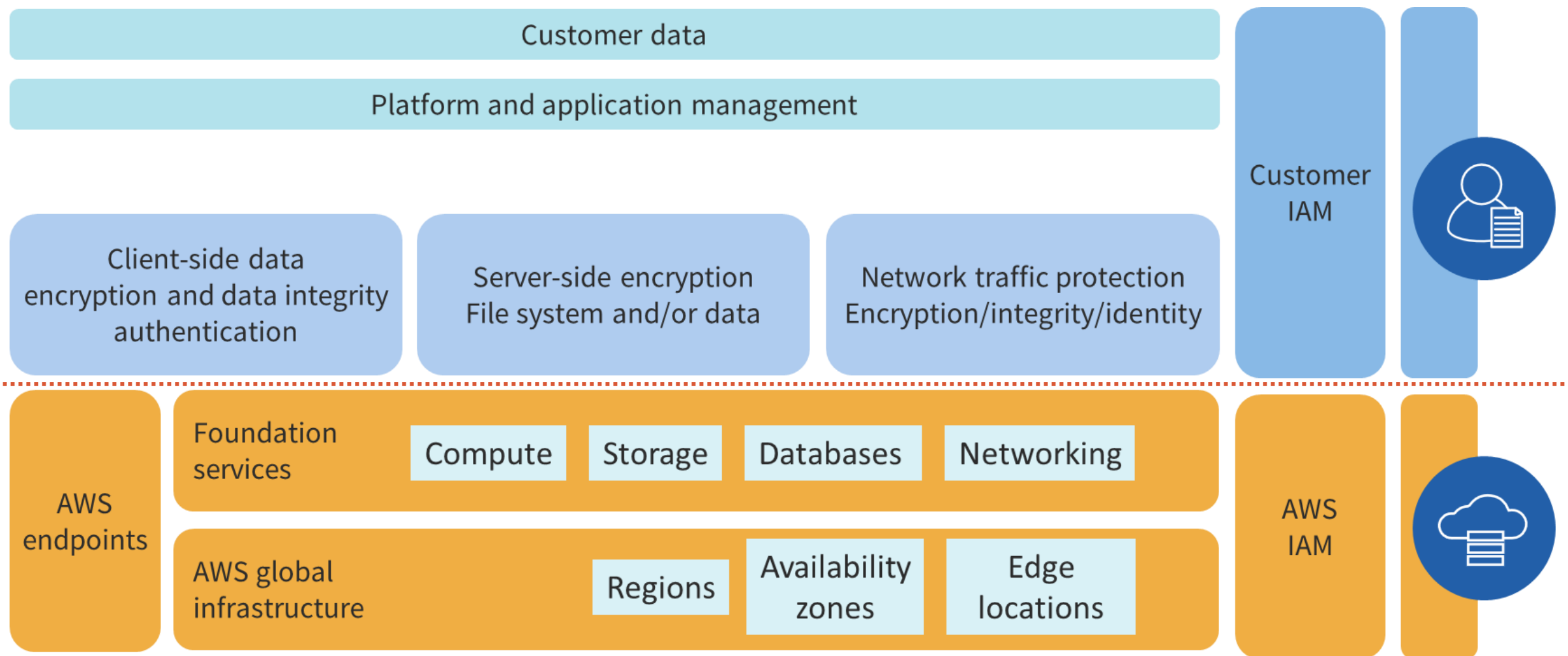
Cloud Computing Characteristics

- **On-demand self-service** allows cloud service customers to provision computing capabilities as needed, automatically, or with minimal interaction with their service provider
- The feature helps users save on cost, time, and effort since they can do what they need, when they need to, without added interactions or overhead

Cloud Service Types



Infrastructure-as-a-Service (IaaS) at AWS



Platform-as-a-Service (PaaS)



Development and SDK
platforms for Java, PHP,
Python, etc.



Container services for
Docker and Kubernetes



Managed and fully
managed relational and
document databases

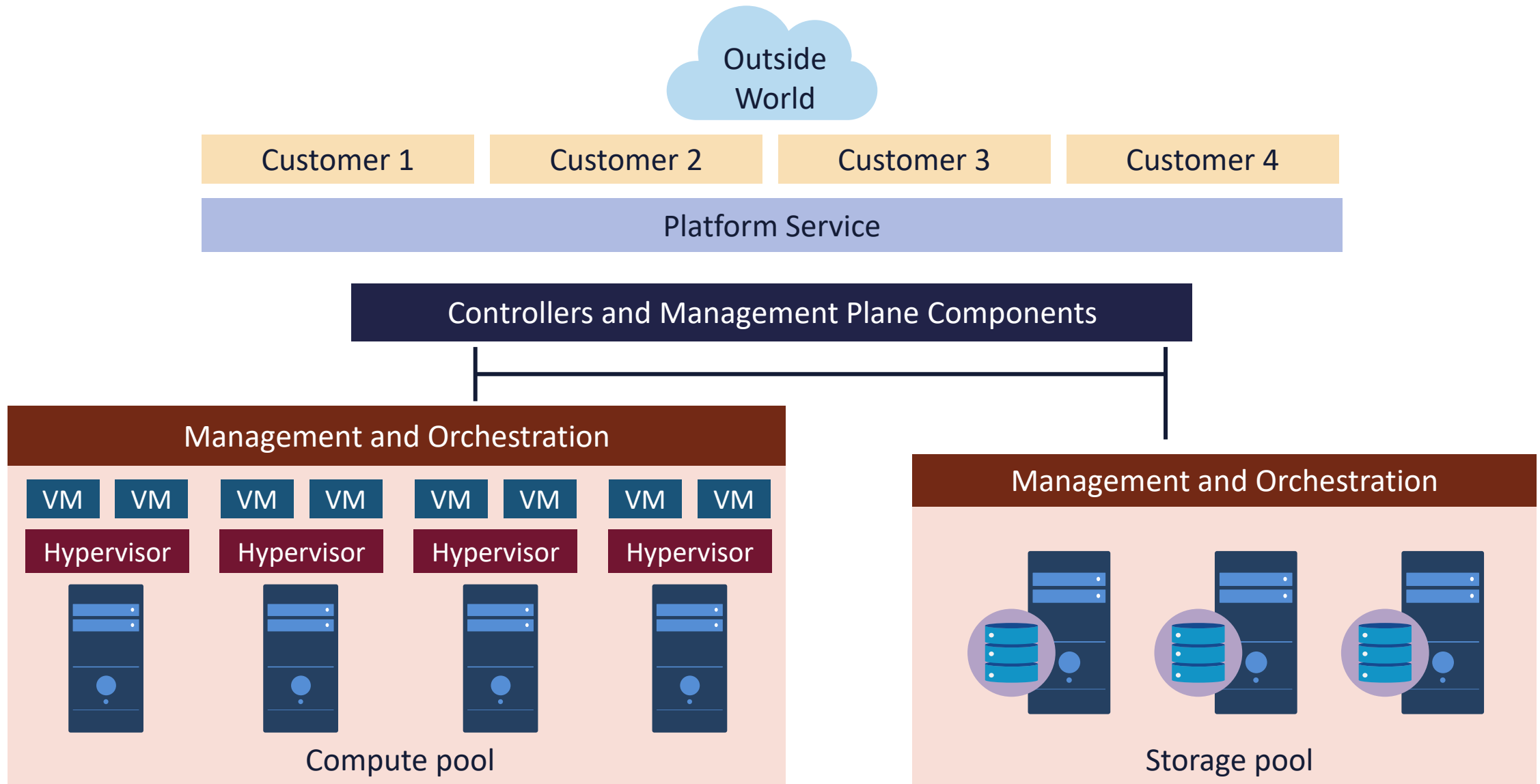


Managed security and
threat modeling
services



SSO, machine learning,
AI, IoT, blockchain,
media services

Simplified PaaS Architecture

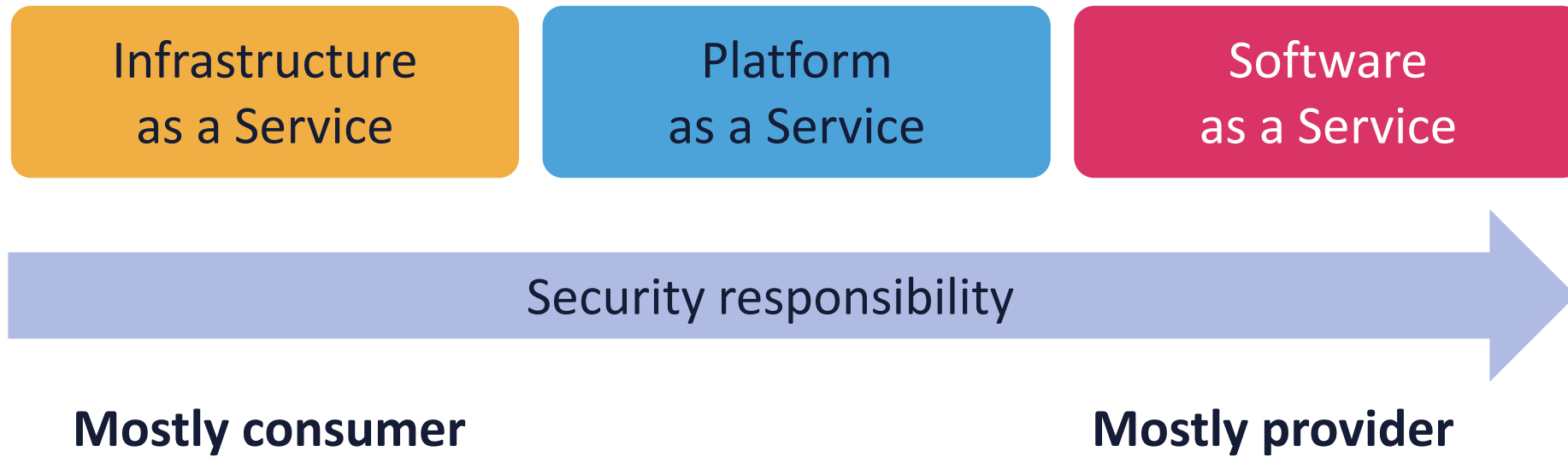


Software-as-a-Service (SaaS)

- Customer relationship management (CRM)
- Enterprise Resource Planning
- Human resources and workplace tools
- Finance, sales, and marketing services
- Payroll services
- E-mail, collaboration, and cloud storage
- Help and service desk
- Virtual call center
- Business analytics
- SIEM and SOAR systems



Service Type Shared Responsibility

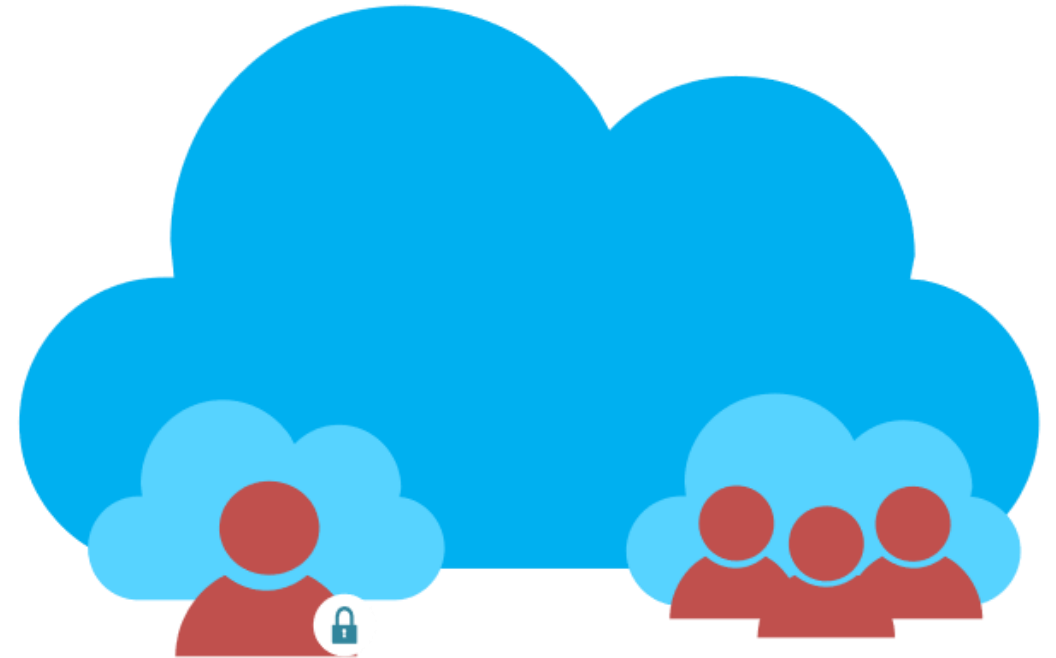


Azure Shared Responsibility Model (SRM)

Responsibility	SaaS	PaaS	IaaS	On-prem	
Information and data					Customer responsibility
Devices					
Accounts and identities					
Identities and directory infrastructure					Responsibility varies by service type
Applications					
Network controls					
Operating systems					
Physical hosts					Responsibility moves to cloud provider
Physical network					
Physical datacenter					
Microsoft  Customer 					

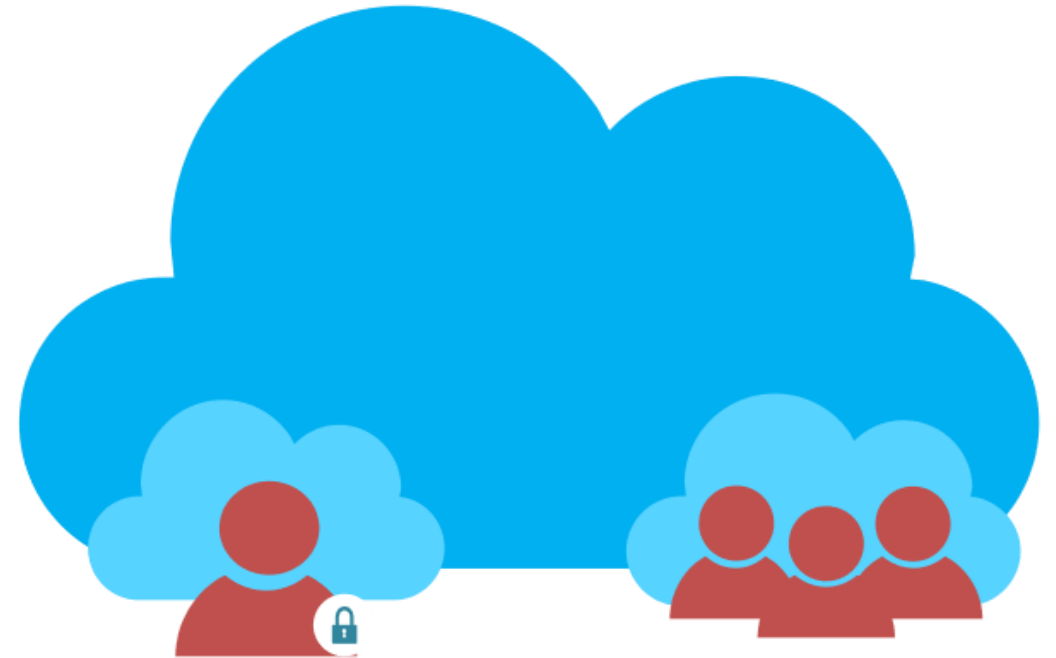
Cloud Deployment Types: Public

- A model where computing resources are owned and operated by a provider and shared across multiple tenants via the Internet or other public networks
- Enterprises often use public cloud for less-sensitive applications that have unpredictable spikes in usage or for storing data that does not require frequent access



Cloud Deployment Types: Public

- Public cloud makes computing resources available to anyone for purchase and multiple users usually share the use of a public cloud
- Many businesses use a public cloud to scale existing IT resources on demand without having to commit to growing their physical IT infrastructure



Cloud Deployment Types: Private

- A model that is dedicated to a single customer (or organization) with no other sharing of cloud resources – not a multi-tenant environment
 - The private cloud can be a dedicated part of the Cloud Service Provider in a sandbox environment for an additional cost
 - The private cloud can be an on-premises solution using virtualization and other cloud service characteristics



Cloud Deployment Types: Community

- Linking infrastructure and applications between similar entities in a certain sector (public or private use)
 - Often used to share information and research among parties with various types of cooperative relationships
- Common examples are:
 - Government agencies and departments
 - Healthcare provider networks
 - Gaming communities
 - Insurance holding companies
 - Financial services companies



Cloud Deployment Types: Hybrid

- Technically a combination of private, public, and/or community cloud deployments
- Can also be a method for connecting infrastructure and apps between cloud-based resources and other resources that are not placed in the cloud
- The most common type of hybrid deployment is between the provider's Public cloud and a standing on-premises enterprise Private cloud



Cloud Deployment Types: Hybrid

- Can be used to migrate, expand, or grow an organization's infrastructure into a cloud solution while linking internal systems to cloud resources
 - Often used by organizations to "burst up" to the cloud during peak demand times or special situations
- May also refer to "edge" or "fog" computing where the consumer has a direct high-speed connection to the provider cloud through a partner (AWS Direct Connect, Google Interconnect)



Cloud Deployment Types: Multi-cloud

- Multi-cloud is a cloud computing model where an enterprise leverages a combination of clouds (two or more public clouds, two or more private clouds, or a combination of public, private and edge clouds)
- Enables the distribution of applications and services to accelerate app transformation and the delivery of new apps



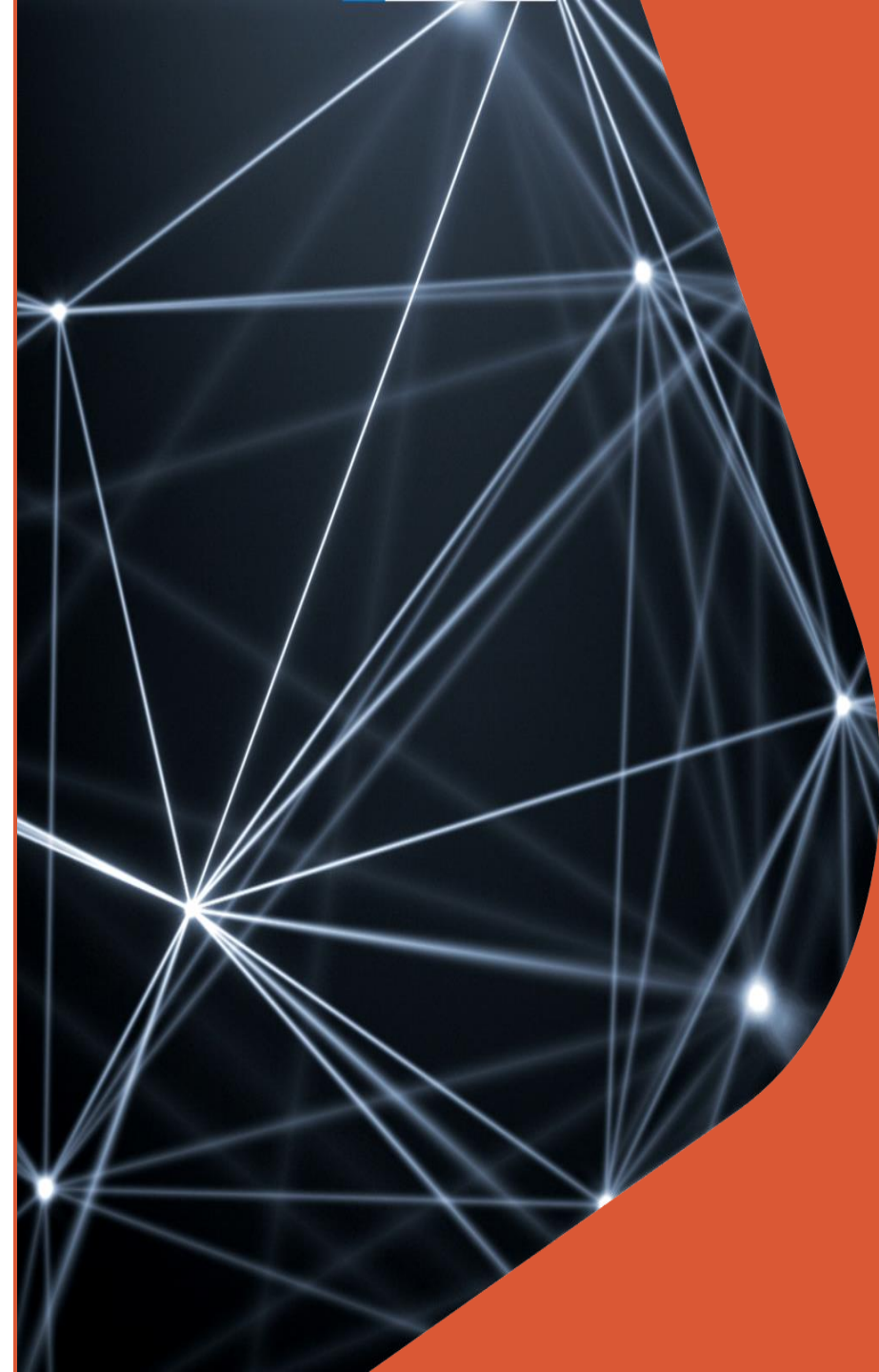
Cloud Deployment Types: Multi-cloud

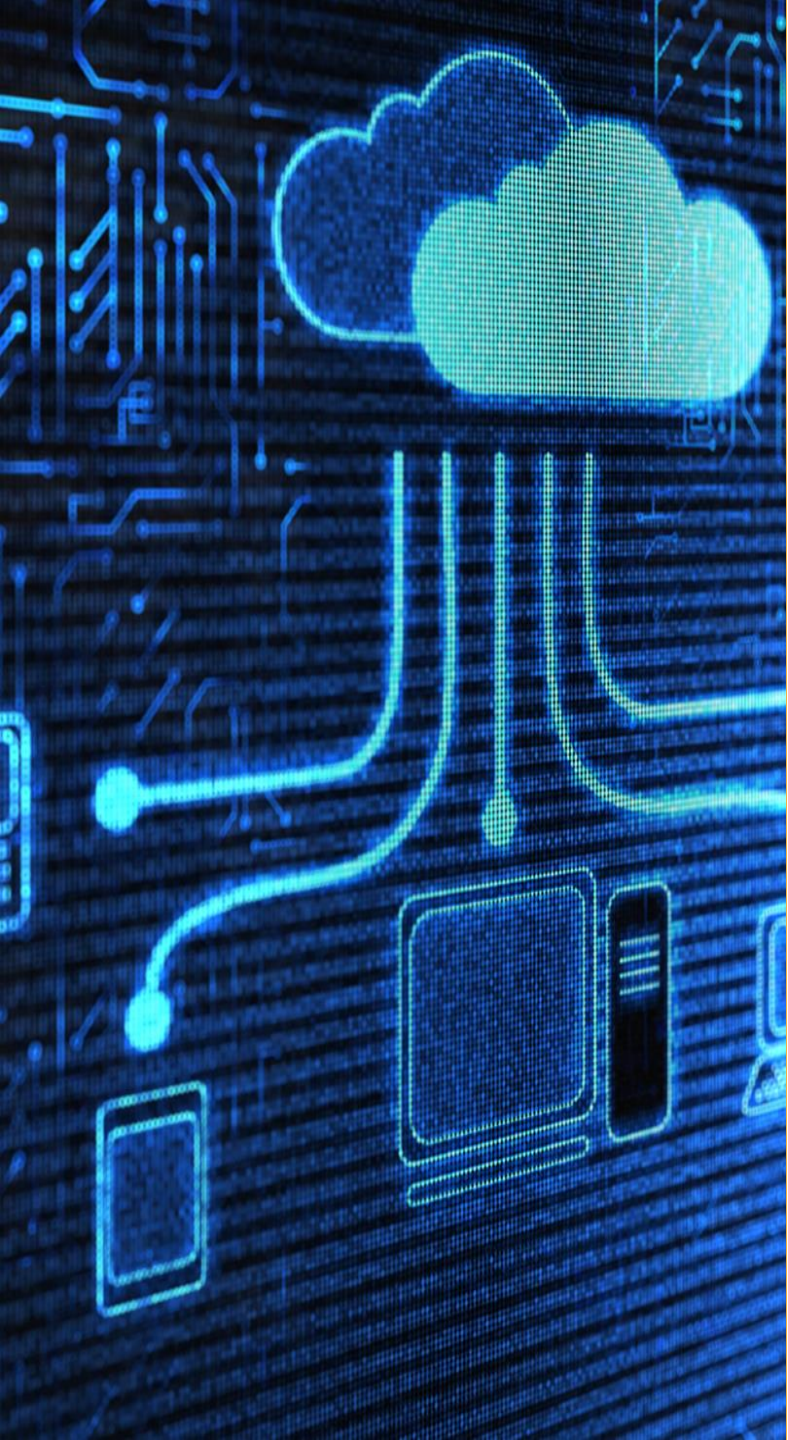
- Allows for allocation of applications and services to the edge in industries such as logistics, retail and manufacturing
- Improves the customer experiences that require applications to be distributed to the edge, closer to physical devices and users
- Supports the rise of the distributed workforce that secure and manage users and their devices



Cloud Logical Models

- **Infrastructure Layer** – Security of the infrastructure which includes the data center network, storage, and servers
- **Metastructure Layer** – Securing the virtual environment which represents the logical layer using tools and configuration of the management plane often using software-defined networking (OpenFlow and Cisco ACI)
- **Infostructure Layer** – Where the data and information reside
- **Applistructure Layer** – server-based and serverless cloud-native applications and services





Governance

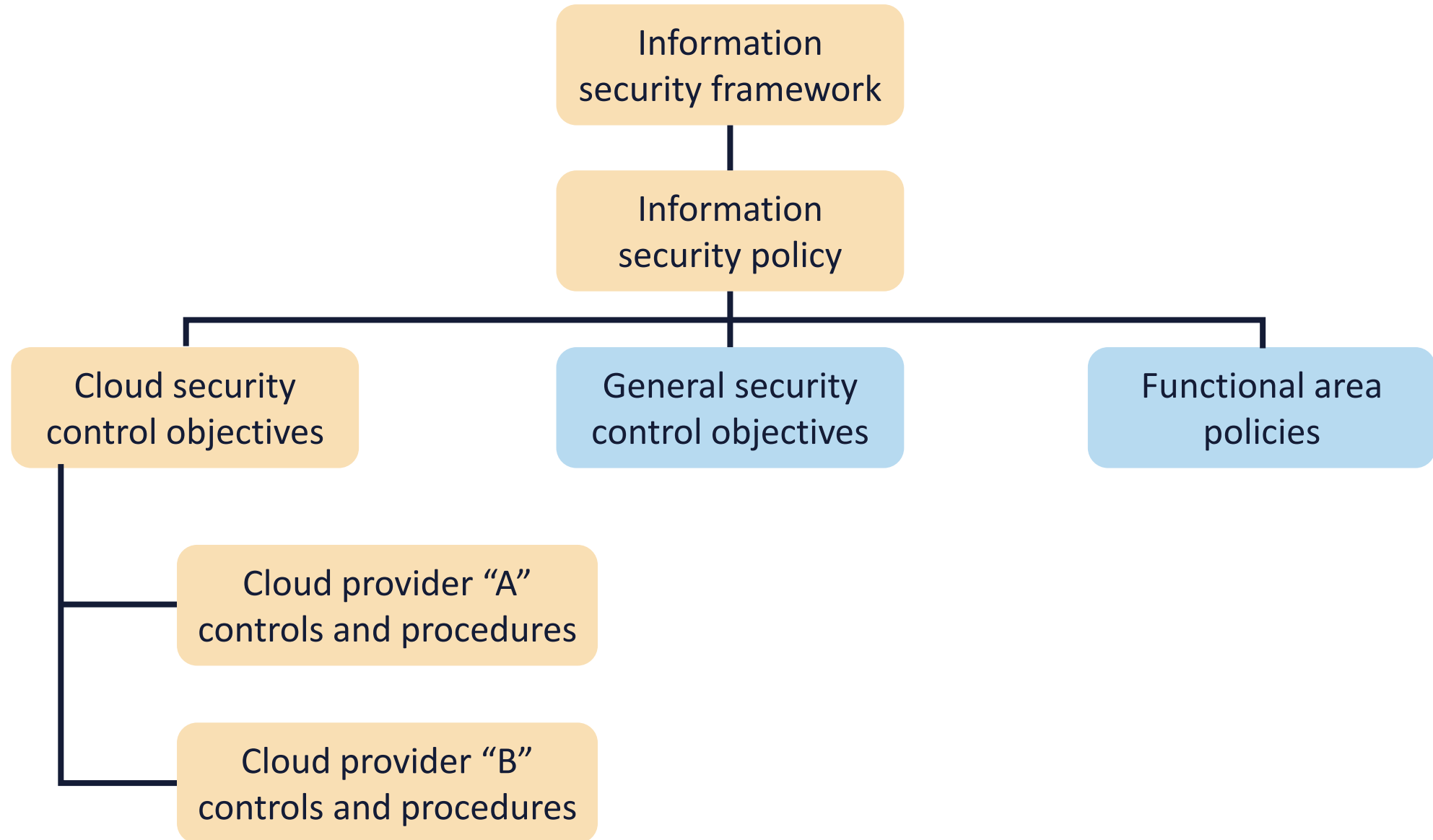
- According to ISACA: "Governance ensures that stakeholder needs, conditions and options are evaluated to determine balanced, agreed-on enterprise objectives to be achieved; setting direction through prioritization and decision making; and monitoring performance and compliance against agreed-on direction and objectives."
- It typically focuses on three attributes or characteristics:
 - authority
 - decision-making, and
 - accountability

Effective Cloud Governance

- Defining roles and responsibilities
- Conducting requirements and information gathering
- Managing risks
- Classifying data and assets
- Complying with legal and regulatory requirements
- Maintaining a cloud registry
- Establishing a governance hierarchy
- Leveraging cloud-specific security frameworks



Security Governance Hierarchy



Cloud Governance Tools

Cloud Provider Assessments

- Customers must perform their due diligence exercise before selecting a provider/vendor
- Assessments should take advantage of all available information and collection tools
- It is almost impossible that a customer will be able to go to a cloud provider datacenter and conduct an audit or assessment
- **The Cloud Controls Matrix (CCM+CAIQ) and CSA Star registry are the primary methods for provider assessment for this exam – these will be explored in greater detail later in the course**

Cloud Governance Tools

Compliance Reporting

- **ISO/IEC 27017** – based on 27002 control set but customized for cloud services
- **NIST 800-53** – more than 600 controls as part of the larger NIST Risk Management Framework
- **FedRAMP** – modifies 800-53 for providers who want to have Authority to Operate (ATO) with US government
- **PCI** – Bank cards and credit card data risk compliance
 - Just because a provider is PCI compliant does not mean your applications are compliant
- **COBIT** – ISACA IT enterprise management and governance (instead of ITIL 4)
- **HIPAA/HITECH** – security and privacy of PHI

Comparing Security Auditing Standards

Standards applicable to cloud security auditing.

Standard	Type	Strength	Sponsoring organization
Service Organization Control (SOC) 2	Audit for outsourced services	Technology neutral	American Institute of CPAs
ISO 27001 and 27002	Traditional security audit	Technology neutral	ISO
NIST 800-53 rev, 4	Federal government audit	Technology neutral	National Institute of Standards and Technology
Cloud Security Alliance (CSA)	Cloud-specified audit	Dedicated to cloud security auditing	CSA
Payment Card Industry (PCI) Data Security Standard (DSS)	PCI Qualified Security Assessor cloud supplement	Cloud specific and Provides guidance	PCI DSS

Security Policies

- Information security policies are crucial for establishing a strong security framework
- They govern the protection of an organization's information assets, outline necessary control objectives, and should require business leadership sign-off to ensure alignment with strategic goals
- An Information Security policy is a top-level policy defining how the information security program will be run
 - It ideally refers to other policies and documents, such as control objectives, rather than trying to include all the specific technical requirements



Developing Effective Information Security Policies





Policies Should be Sanctioned

- The policies must be authorized
- A policy requires the support of executive management or the C-suite
- There is often one owner or accountable entity for the security policy (i.e., RACI)
- **This demands visible involvement and ongoing activities such as communication, funding, championing, prioritization, due diligence, and due care**

Policies Should be Applicable

- The policies must be appropriate and relevant to the organization
- They must be in concert with the charters, missions, strategies, and value propositions of the enterprise
- **Templates should be customized as needed to meet this objective**





Policies Should be Realistic

- In actuality, the policies can be effectively executed
- Policies must mirror the actual state of the environment in which they will be applied
- Information security policies and procedures should only demand what is possible in the given time frame
- **Policies (i.e., mock phishing campaigns) should never set up principals for failure or retribution but rather offer a clear track for success**

Policies Should be Flexible

- Policies must be agile and changeable
- An information security policy should accommodate sudden and rapid modifications when necessary
- **This ongoing process designed to support the organizational mission must adapt to new opportunities, technologies, competitors, and business continuity challenges (i.e., pandemics)**





Policies Should be Comprehensive

- The scope of information security policies must be inclusive **and include all applicable internal and external parties (stakeholders)**
- The policies must consider :
 - Customers (internal and external)
 - Shareholders
 - Organization objectives
 - Laws and regulations
 - Cultural norms of employees and consumers
 - Business and strategic partners
 - Vendors and suppliers (supply chain)

Policies Should be Enforced

- The information policies should first be **enforceable** and then subsequently be **enforced**
- When necessary, proper actions will be taken:
 1. Email or phone call reminder
 2. Verbal and/or written warning
 3. Sanctions or removal of privileges
 4. Suspension with pay
 5. Suspension without pay
 6. Termination
 7. Criminal or civil legal action (incarceration, reimbursement, and/or restitution)



Defining Risk



- Inherent (total) risk
 - Risk the organization faces if safeguard is not implemented
- Residual risk
 - Risk that remains once safeguard is in place
- Residual = inherent risk - safeguards (controls)

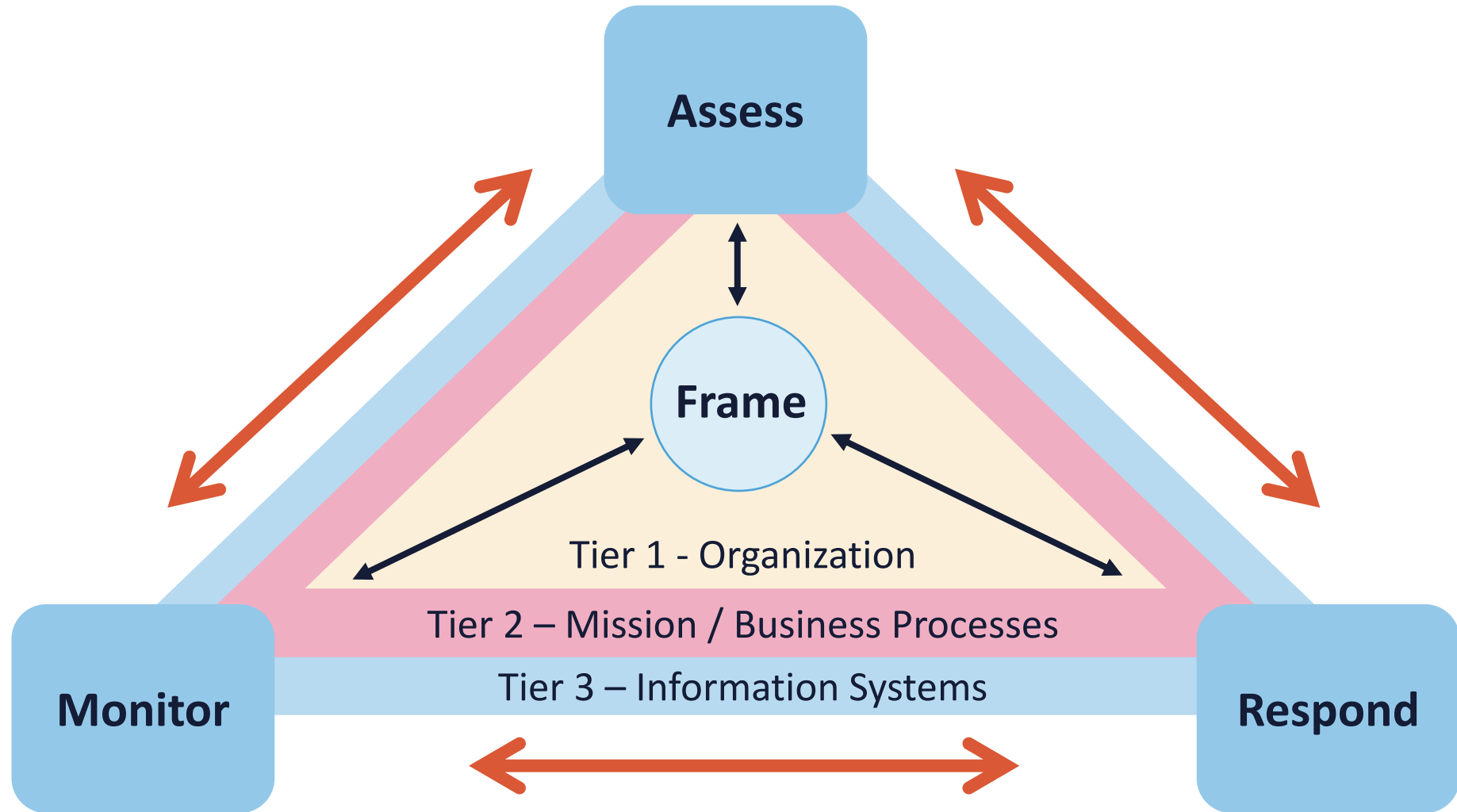
Risk Treatment



Also called risk handling or appetite

- Risk **acceptance**
 - Do not implement any safeguards
 - Justification in writing is often required
- Risk **avoidance**
 - Choose not to undertake actions that introduce risk
- Risk **transference/sharing**
 - Pass the risk to a third-party, such as an insurance company or a cloud service provider
- Risk **mitigation**
 - Implement safeguards that will eliminate or reduce risk exposure - risk may exist, but impact is reduced

NIST SP 800-39



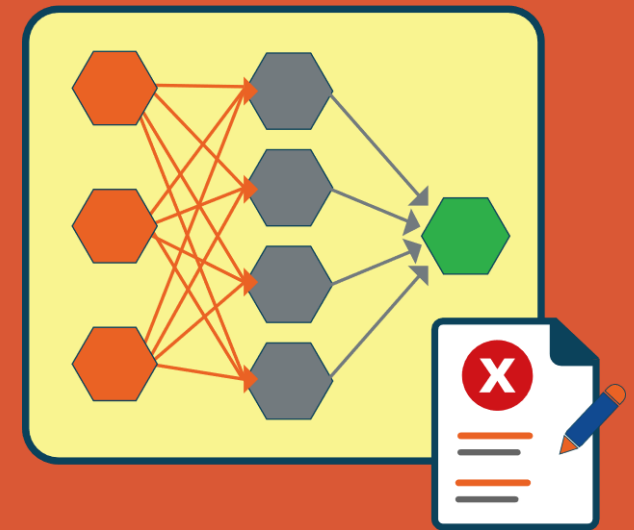
Managing Information Security Risk (NIST SP 800-39)

- **Step 1: Risk Framing**

- Risk framing establishes the context and provides a common perspective on how organizations manage risk
- As its principal output, it produces a risk management strategy that addresses how organizations intend to assess risk, respond to risk, and monitor risk

- **Step 2: Assessing Risk**

- Risk assessment identifies, prioritizes, and estimates risk to organizational
- Risk assessments use the results of threat and vulnerability assessments to identify and evaluate risk in terms of likelihood of occurrence and potential adverse impact (i.e., magnitude of harm) to organizations, assets, and individuals



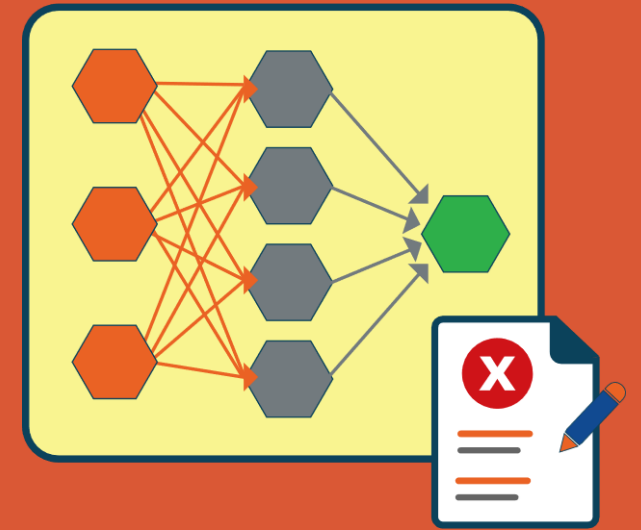
Managing Information Security Risk (NIST SP 800-39)

- **Step 3: Responding to Risk**

- Risk response identifies, evaluates, decides on, and implements appropriate courses of action to accept, avoid, mitigate, share, or transfer risk to organizational operations and assets, individuals, other organizations, and the country, resulting from the operation and use of information systems

- **Step 4: Monitoring Risk**

- The goal is to verify compliance; determine the ongoing effectiveness of risk response measures; and identify risk-impacting changes to organizational information systems and environments of operation
- Analysis gives organizations the capability to maintain awareness of the incurred risk, highlight the need to revisit other steps in the risk management process, and initiate process improvement



Qualitative Risk Analysis

The most common method used in risk and security



- Descriptive approach using subjective opinions, history, and scenarios to determine risk levels
 - Expert judgement
 - Best practices
 - Experience
 - Intuition
- Often involves interviewing people (Delphi) regarding assets, known risks, known vulnerabilities, common threats, and historical impacts

Qualitative Heat Map

			Impact				
Likelihood			Negligible	Minor	Moderate	Critical	Disastrous
			1	2	3	4	5
	Frequent	5	Medium	Medium	High	High	High
	Likely	4	Medium	Medium	Medium	High	High
	Occasional	3	Low	Medium	Medium	Medium	High
	Seldom	2	Low	Low	Medium	Medium	Medium
	Improbable	1	Low	Low	Low	Medium	Medium

Semi-Quantitative Risk Analysis

Impact

- Negligible = 1 (no impact)
- Minor = 2 (< \$1 million)
- Moderate = 3 ($\geq$ \$1 million)
- Critical = 4 ($\geq$ \$100 million)
- Disastrous = 5 (complete)

Likelihood

- Improbable = 1 (almost never)
- Seldom = 2 (not in 5 years)
- Occasional = 3 (once in last 5 years but not in last year)
- Likely = 4 (once in last year)
- Frequent = 5 (several times a year)

Risk of event = 4 (material impact) X 3 (moderate likelihood) = 12

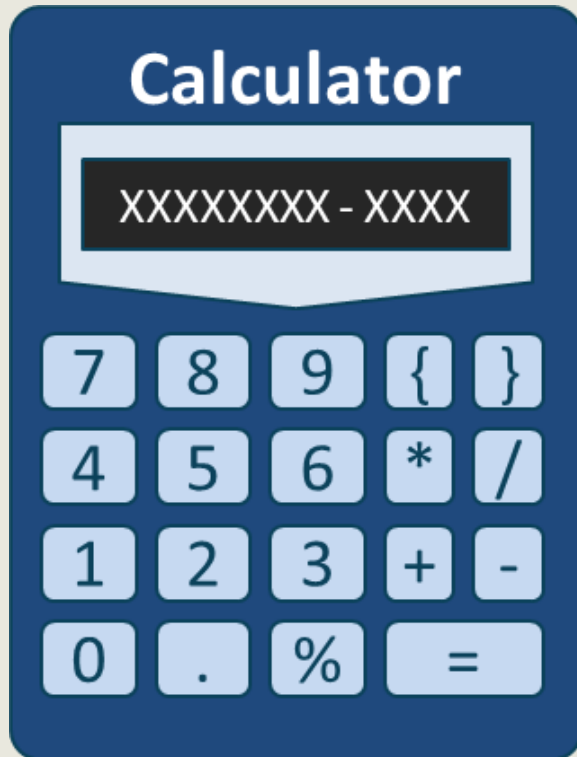
Quantitative Risk Analysis

Rapidly gaining popularity due to FAIR analysis



- A scientific/mathematical approach to getting monetary and numeric results based on the following:
 - Asset values
 - Impact and magnitude (Severity of incident)
 - Probability and likelihood of occurrence (Threat Frequency)
 - Costs and effectiveness of safeguards
 - Probabilities based on percentages and calibrated estimation
 - **The Goal is to find the 90 percentile**

Classic Quantitative Analysis (Whitman)



- **AV** (asset value)
 - Value of the asset according to the organization
- **EF** (exposure factor)
 - Percentage of asset loss caused by identified threat
- **SLE** (single loss expectancy)
 - Potential loss if attack occurs
 - (Asset value * exposure factor)
- **ARO** (annualized rate of occurrence)
 - Estimated frequency the threat will occur within a single year
- **ALE** (annualized loss expectancy) = (SLE * ARO)

Classic Quantitative Analysis (Whitman)

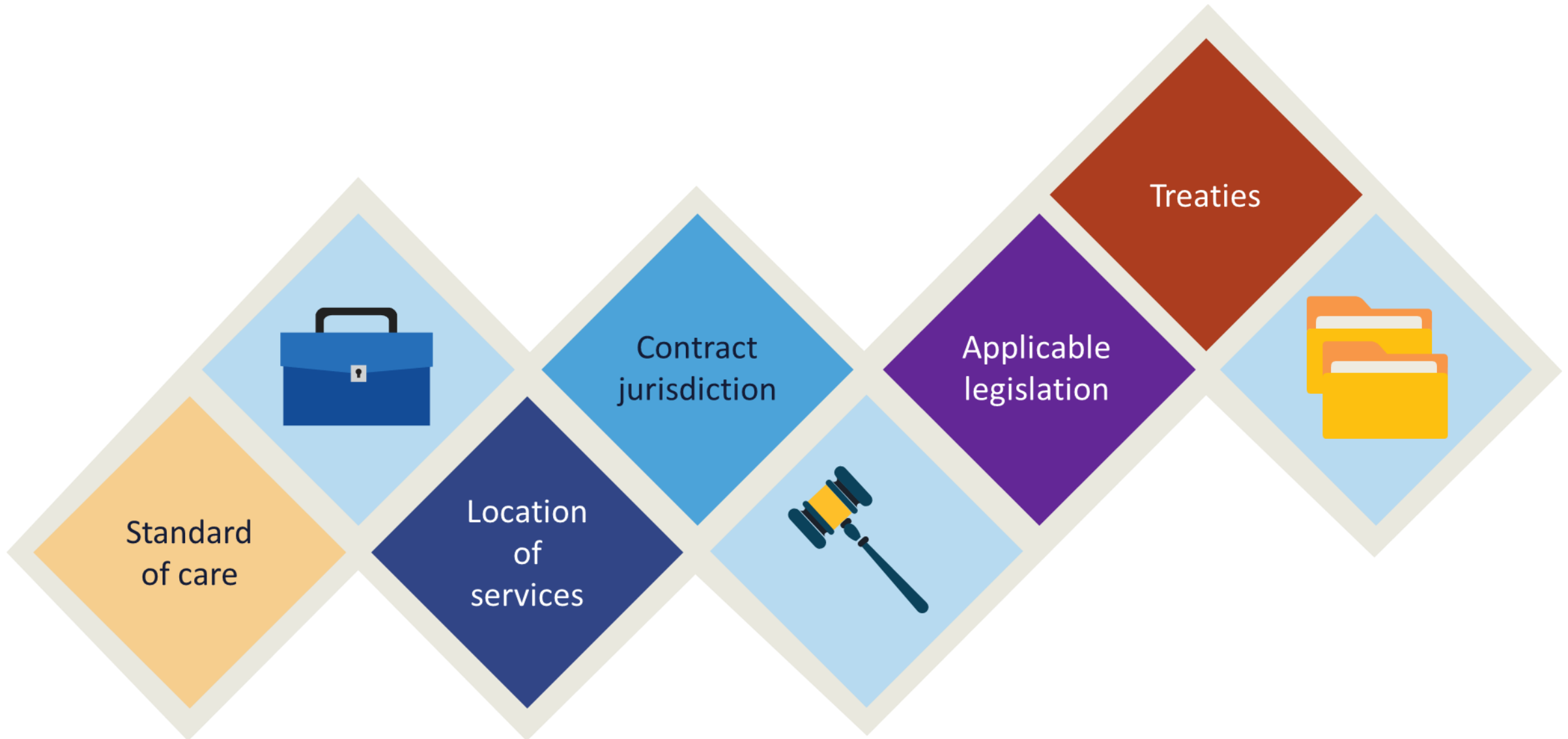
Risk analysis						
Asset	Threat	Asset value	Exposure factor	Single loss expectancy	Annualized rate of occurrence	Annualized loss expectancy
SRV_1	Fire	\$15000	100%	\$15000	0.1	\$1500
SRV_2	Fire	\$20000	100%	\$20000	0.1	\$2000
SRV_1	Flood	\$15000	100%	\$15000	0.0001	\$1.5
SRV_2	Flood	\$20000	100%	\$20000	0.0001	\$2.0
SRV_1	Virus (no AV software)	\$15000	10%	\$1500	365	\$547,500
SRV_1	Virus (with AV software)	\$15000	10%	\$1500	1	\$1500

Compliance & Audit



- Compliance involves following a set of requirements derived from internal policies, relevant laws and regulations, industry-specific codes of conduct and practices, standards, and best practices
- Adhering to these requirements enables organizations to meet internal policies and ethical codes, operate safely in the market, and sometimes gain a competitive edge by conforming to international standards

Legal Facets when using Cloud Services



Standard of Care

- The standard of care is a legal term that is applied to determine if a person or company should be held responsible for harming others and thus should be made to compensate victims
- A standard of care exists when people or companies engage in certain activities or provide certain services
- **A common practical example would be a cloud-based healthcare system or community cloud**



Cloud Governance Tools

Contracts

- In addition to bilateral instruments, contracts include (but are not limited to):
 - Awards and notices of awards
 - Job orders or task letters issued under basic ordering agreements
 - Letter contracts
 - Orders, such as purchase orders, under which the contract becomes effective by written acceptance or performance
 - Bilateral contract modifications

Common Contract Documents

- **Terms and Conditions** – Key document that defines service situations, data usage, termination options, warranties, legalities, and more
- **Acceptable Use Policy (AUP)** – states how the services can be utilized
- **Service Terms** – provider-specific contractual agreements
- **SLA/OLAs** – defines performance metrics for external and internal vendors and providers
 - SLA is also called Master Service Agreements (MSA)
- **Specific Clauses**



Service Level Agreements (SLAs)

- Define the precise responsibilities of the service provider and set customer expectations
- Also clarify the support system (service desk) response to problems or outages for an agreed level of service
- Can be internal between business units or departments, as well as external
- Should be used with new third-party vendors or cloud providers (SaaS, IaaS, PaaS) for 24-hour support

Master Service Agreement (MSA)



- As part of due diligence in your BCP, you should confirm any/all expectations with the candidate service provider and ensure that they are documented in your MSA/SLAs
- A master service agreement (MSA) is a contract two parties enter into during a service transaction
- This agreement details the expectations of both parties
- The goal of a master service agreement is to make the contract process faster
- It also should make future contract agreements simpler

Non-Disclosure Agreements (NDAs)



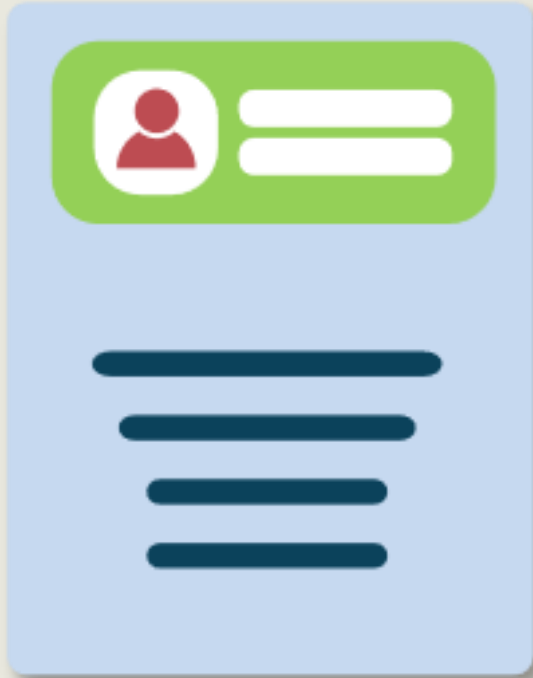
- Also called "Confidentiality Agreements"
- Legal contract between two or more parties
 - Confidential relationship that is often strictly enforced
 - Business to business/business and employee
- Identifies confidential information they wish to share with each other
 - IP, trade secrets, technologies, campaigns, ideas, new processes, new products, and services
 - Restricts the sharing of that information with others

Memorandum of Understanding (MOUs)



- Also called a Memorandum of Agreement (MOA) or "letter of intent"
- A formal MOU (or MOA) usually precedes a more formal agreement or contract ISA
- It defines common courses of action and high-level roles and responsibilities in management of a cross-domain connection
- It will usually terminate the customer's provider search process so that subsequent time and resources can be dedicated to the next steps of the formal contract process

Reciprocal Agreements



- A reciprocal agreement is between two organizations with similar infrastructure and technology – often difficult to legally enforce
- The most common goal is that one can be a recovery site for the other in case of a disaster or lengthy outage
- Also seen with data backup and escrow services whereby two departments or organizations agree to store one each other's backup data on their computers

Treaties

- Treaties are binding agreements between two political authoritative entities and nations and become that part of international law
- Treaties to which the United States is a party also have the force of federal legislation, forming part of what the Constitution calls "the supreme Law of the Land."



Compliance Considerations



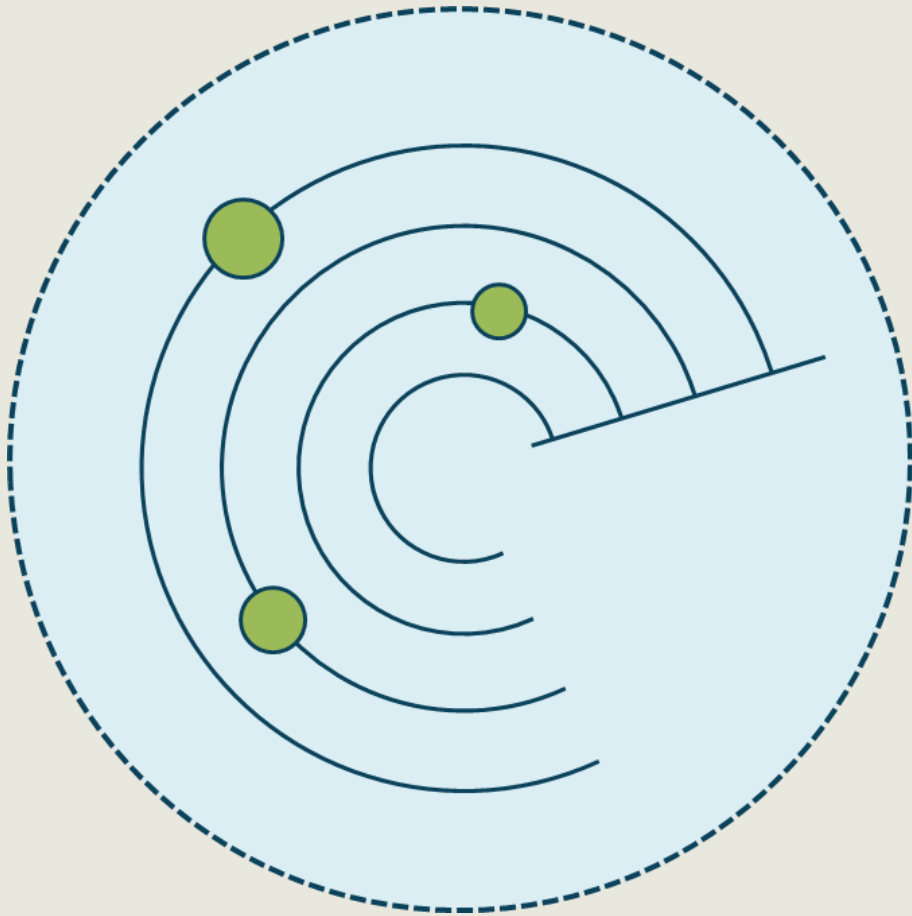
- Considerations of exports of data to foreign jurisdictions
- Application of the Shared Responsibility Model (SRM)
- Complexity and disruptions of the cloud supply chain
- Obtaining documentation, reports, and artifacts from the providers
- Scope of audits and assessments
- Maturity of compliance testing and management
- Provider experience with regulatory entities
- Inheritance of compliance from an IaaS to a SaaS

Statement on Standards for Attestation Engagements (SSAE)



- Statement on Standards for Attestation Engagement (SSAE) 18 is an American auditing standard issued by the AIPCA
- **SOC 1**
 - Report used for Internal Control over Financial Reporting (ICFR) and auditing financial statements
- **SOC 2**
 - Called “Report on Controls at a Service Organization Relevant to Security, Availability, Processing Integrity, Confidentiality, or Privacy”
- **SOC 3**
 - Publicly available “high-level” statement from a CPA that a SOC engagement was conducted

Audit Management in the Cloud



- Audit management assures that the initiatives and directives are implemented in an optimal way:
 - Internal and/or external auditors
 - Purpose and goal of audit
 - Scope of the audit
 - Contribution to risk management and analysis
 - Audit standard operating procedures and processes
 - Available physical and digital resources
 - Scheduling and other logistics (project management)

Audit Mechanisms

Involves tools and techniques



- Various logs (system, application, firewall, etc.) and activity reporting (DAM)
- Simple Network Management Protocol (SNMP) traps and informs
- NetFlow v5 and v9 collections
- Security information and event management (SIEM) and Security Orchestration, Automation, and Response (SOAR) systems
- Next-Gen IPS and IPS
- Change and configuration management
- Cloud-based ML and AI visibility/analysis

Relevant ISO/IEC Compliance Standards

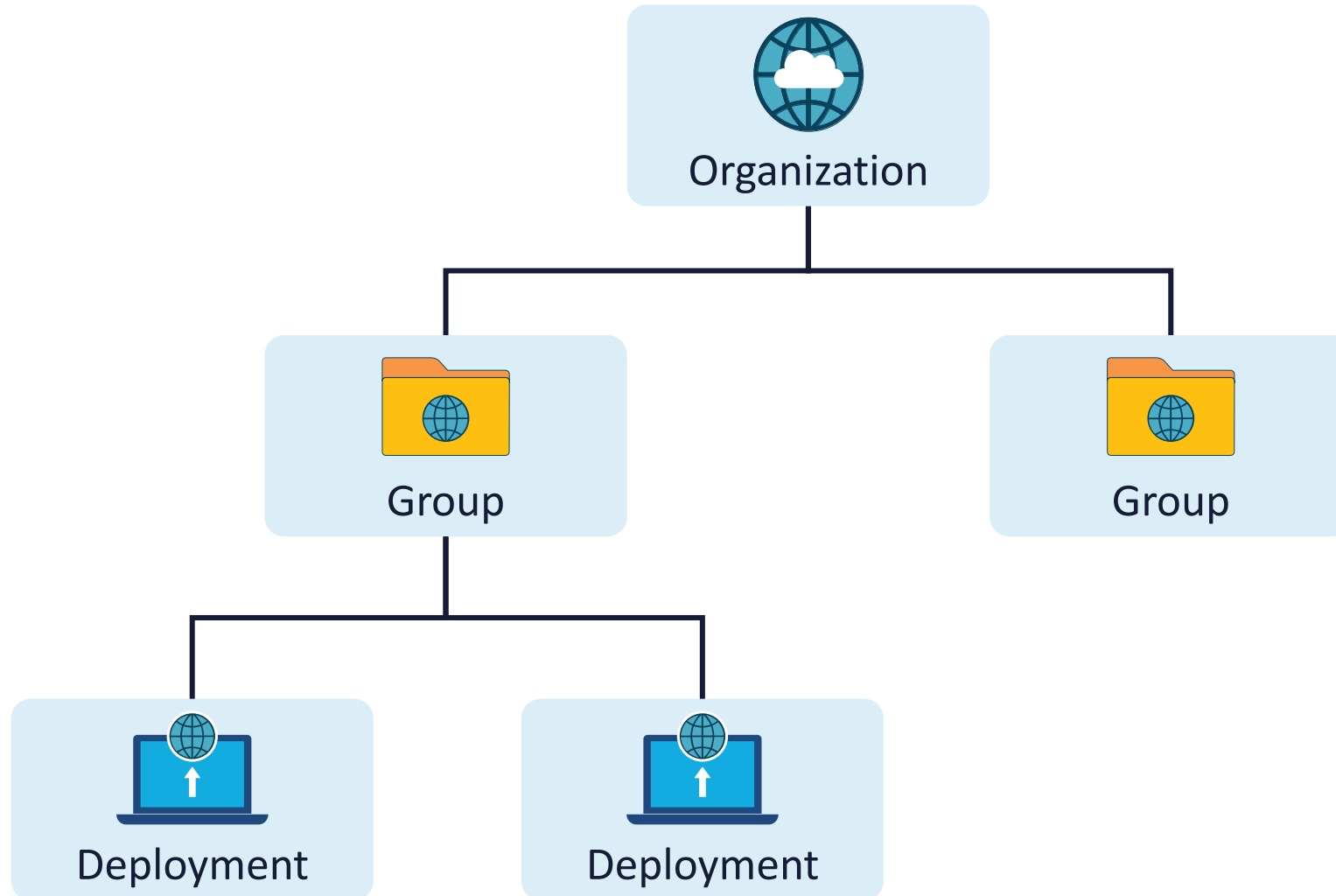
- **27001** - The world's best-known standard for information security management systems (ISMS) and their requirements – has an appendix with list of controls
- **27002** – Code of practice catalog for ISMS that lists controls (over 130) and guidance serving as best practice recommendations
- **27005** – Information security risk management guidelines document to assist with 27001 compliance
- **27017** – Set of security controls from 27002 that are modified for cloud services by adding cloud-specific controls (cloud service extended control set)
- **27018** – The code practice for protection of personal data (PII) in cloud computing environments

CSP Organizational Structures

- Different CSPs use different words for similar organizational structures. Here are the terms that are often used:
 - An "organization" denotes the highest level of structure within a CSP cloud provider
 - A "group" represents a collection of deployments
 - A "deployment" refers to an isolated environment within a CSP cloud provider



CSP ORGANIZATIONAL STRUCTURES





CSP Policy Categories

- **Organization-wide policies** are defined by the customer and apply to every deployment within the CSC
 - This category includes a limited set of policies due to the challenges in managing exceptions on such a broad scale
- **Group-level policies** that cover all deployments within a specific group
 - This level is commonly used for policy application, with the ability for policies at this level to gather and reinforce one another, when applied to sub-groups
- **Deployment-level policies** are tailored for individual deployments, allowing for precise security adjustments
 - Although applying policies at the group level is typically seen as a better management practice, there are certain situations that require deployment-level policies, especially for specific and detailed security needs

Building a Hierarchy Within a Provider

- Cloud Service Customers (CSCs) usually embrace one of three models to define their hierarchy, each with its own advantages and operational implications
- No single model is generally better, and some CSCs may combine elements from different models to best reflect their operational realities

Business Unit and Application-based Model

- This model organizes the cloud hierarchy by placing business units at the top, followed by applications within these units, and then environments such as production and development
- While it aligns well with IAM hierarchies focused on business units, it may be less efficient for policy management unless cloud features are closely aligned with business units and applications



Environment-Based Model

- This model prioritizes environments (e.g., development, production, testing) at the top, followed by business units or applications
- It enhances policy management by setting foundational security and operational policies for various environments, although it may not align well with IAM hierarchies or meet billing and cost management requirements



Geography-Based Model

- This model starts with geographic regions (e.g., EMEA, NA, specific countries) at the top, followed by business units or environments
- It benefits global CSCs with diverse security and regulatory requirements specific to each region





Considerations for Hybrid and Multi-Cloud Deployments

- In the complex landscape of modern IT, Cloud Service Customers (CSCs) frequently employ hybrid and multi-cloud strategies to meet their operational requirements
- Hybrid cloud configurations combine on-premises data centers with public cloud platforms, enhancing flexibility and scalability while presenting unique security challenges
- On the other hand, multi-cloud approaches utilize multiple Cloud Service Providers (CSPs) to avoid vendor lock-in and improve performance, though they introduce additional complexities in managing security

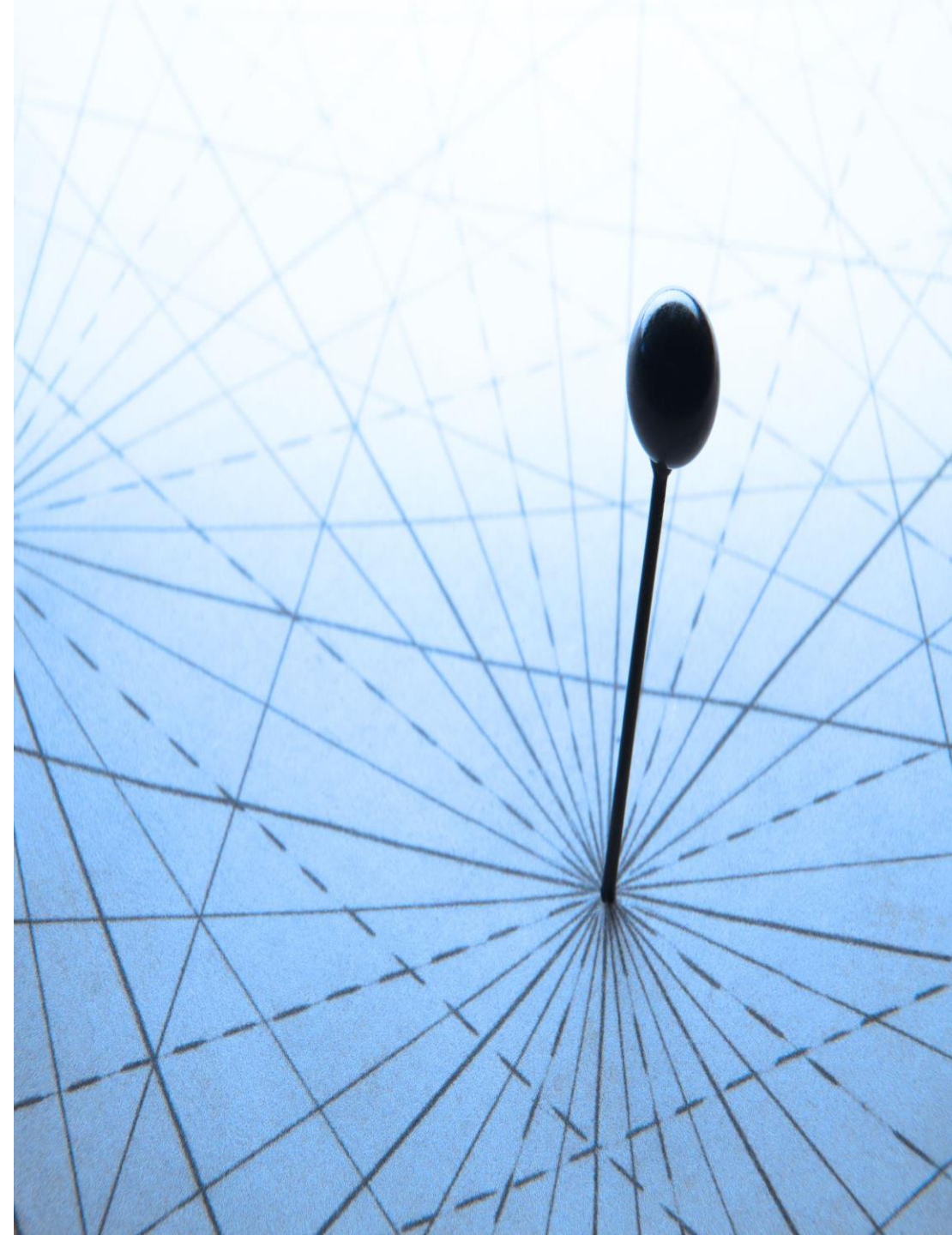
Hybrid Cloud Considerations

- A hybrid cloud integrates an existing data center or facility with a public cloud provider using a VPN, SDP, or dedicated network link.
- To achieve strong hybrid cloud security, CSCs should ensure robust security measures in both cloud and data center environments
- If there are weaknesses in either area, they are isolated and compartmentalized to prevent vulnerabilities from affecting the other environment



Hybrid Cloud Considerations

- It is important to avoid normalizing security controls between hybrid cloud environments, as cloud technologies and data centers have differences
- **Hybrid cloud sprawl**, which occurs when multiple data centers are connected to various cloud deployments through different VPNs or dedicated links and multiple identity providers, can heighten security challenges





Multi-cloud Considerations

- Organizations should avoid expanding to a secondary IaaS CSP until they have developed a robust security program for their primary provider
- Mergers, acquisitions, or specific business demands often lead to multi-cloud deployments
- Organizations must prioritize expertise, implement well-crafted management strategies, and deploy tailored security services designed to support multi-cloud environments

Multi-cloud Organizational Strategies

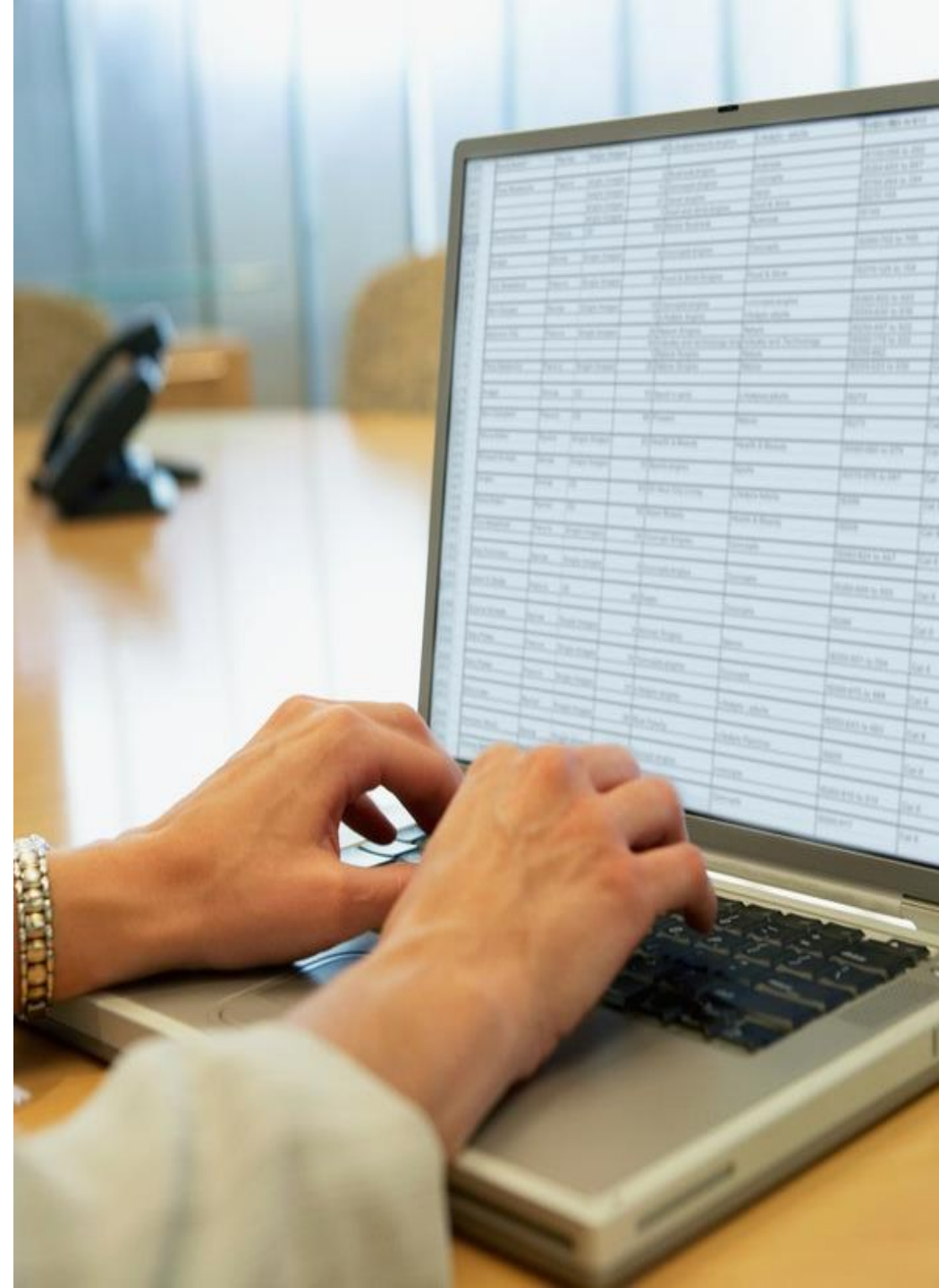
- **Single provider:** The organization uses one CSP for IaaS deployments
 - If an additional CSP is added due to merger or acquisition, that deployment is migrated to the primary CSP
- **Primary/secondary:** All new deployments go to a primary CSP, representing the CSC's main cloud footprint
 - Additional CSPs are used for limited or isolated deployments, approved only if the primary CSP cannot meet specific needs or due to merger or acquisition
 - Secondary CSPs are tightly locked down and use minimal services to reduce security and operational complexity
- **Full multi-cloud support:** The CSC equally supports two or more major CSPs

Managing Multiple SaaS CSPs

- **Federated Identity Brokers:** Equipped with pre-built integrations for major CSPs and a unified dashboard, these solutions can greatly simplify the CSC and lifecycle management of user access and permissions across all cloud models, especially SaaS
- **Cloud Access Security Brokers (CASB):** CASBs can be very useful for managing a CSC's SaaS portfolio, offering access control and monitoring capabilities, and enforcing which SaaS CSCs are utilized, by which users, and from various locations
- **API Gateways:** Interactions between SaaS applications and other applications generally work over APIs so API gateways can bring visibility, control, and policy enforcement over a wide variety of interactions

Major Differences in IAM for Cloud Computing

- Identity and Access Management now extends across various organizations in the realm of cloud computing, with customers utilizing multiple cloud providers and services.
 - Identity Federation fosters trust between organizations by employing standards-based technologies





Major Differences in IAM for Cloud Computing

- Cloud providers leverage various IAM systems with differing technologies, architectures, and terminology.
 - Cloud consumers must learn and implement multiple models, adding complexity to the management plane and infrastructure.
- Cloud providers integrate management and administrative functions into unified web consoles and API interfaces.

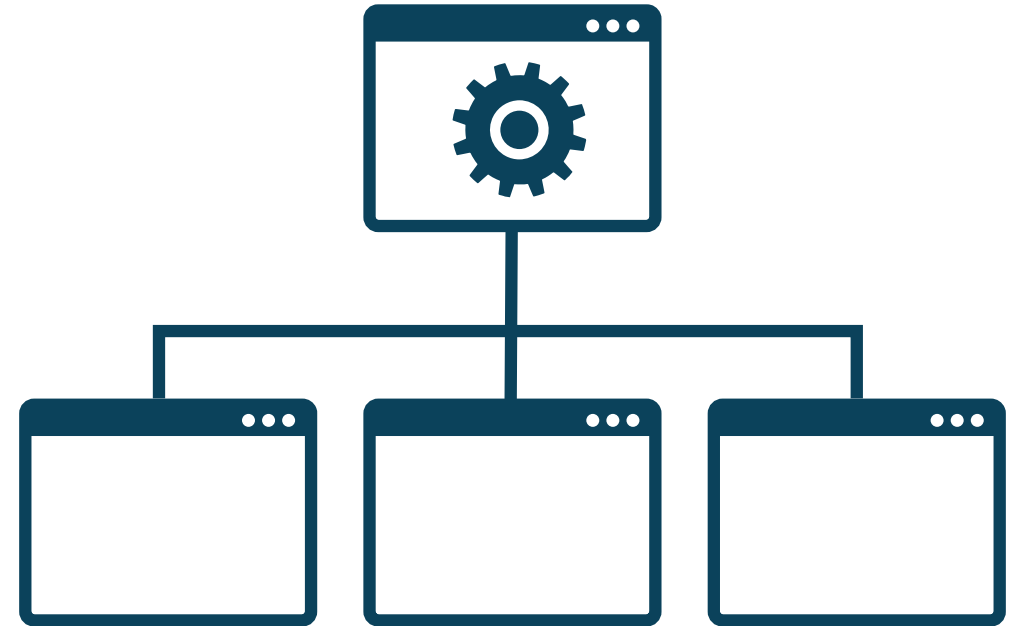
Access Control Models

- Role-based (RBAC)
- Rule-based
- Discretionary (DAC)
- Mandatory (MAC)
- Attribute-based (ABAC)
- Policy-based (PBAC)

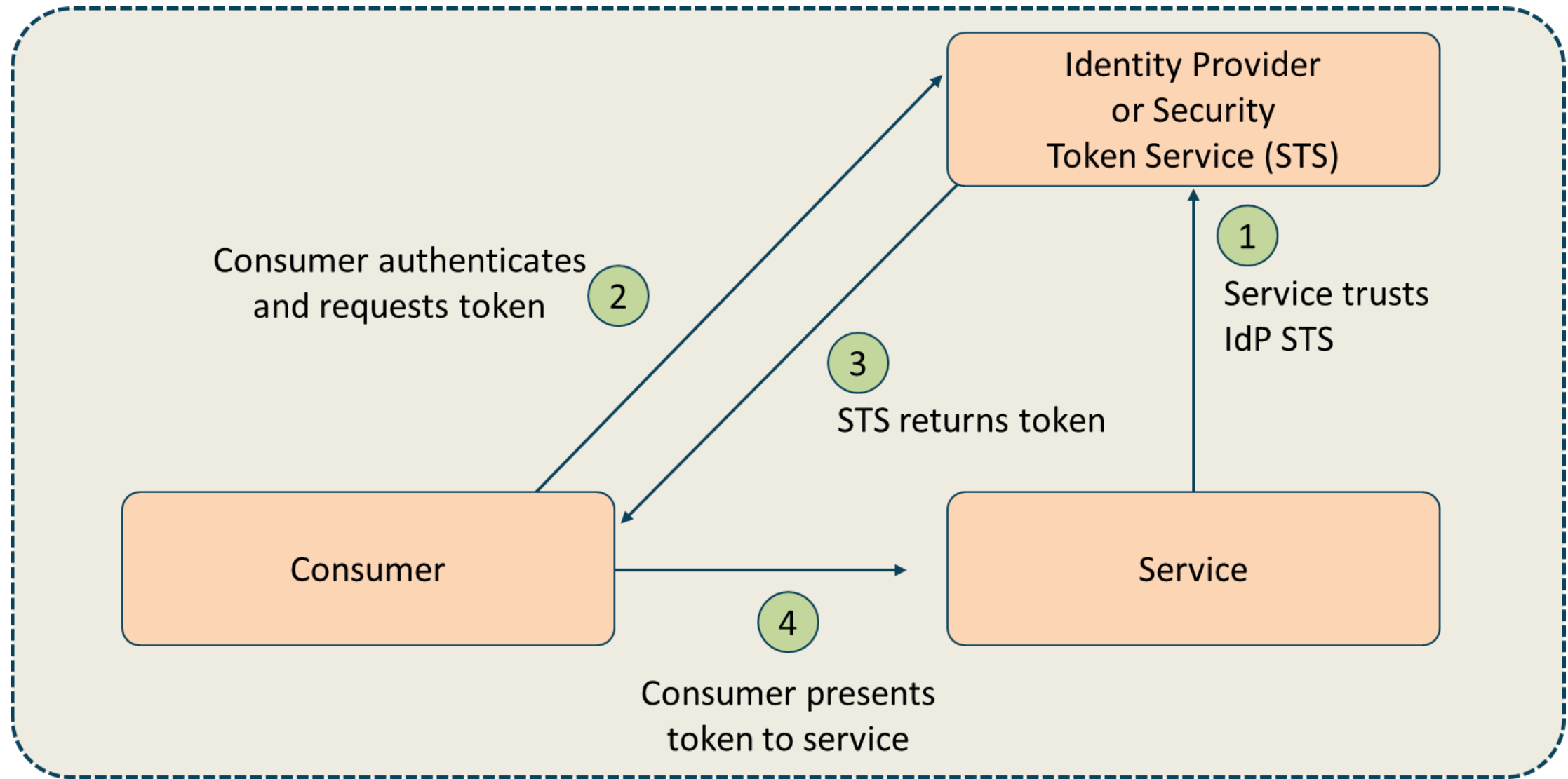


Federation Standards

- Federation is used to manage identities across different organizations, realms, and domains
- It provides single sign-on (SSO) for multiple organizations and service providers
- It is a web-of-trust model is where each member of the federation approves each other member
- The third-party identifier model relies on a trusted third-party



Federated Identity Providers



SAML 2.0

- Security Assertion Markup Language
- SAML is an XML-based open-source SSO standard
- **SAML is used by many cloud SSO connections for thousands of large enterprises, government agencies, and service providers that communicate on the Internet**
- Key advantage of SAML is open-source interoperability
- Some large companies now require SAML for Internet SSO with SaaS applications and other external ISPs

OAuth



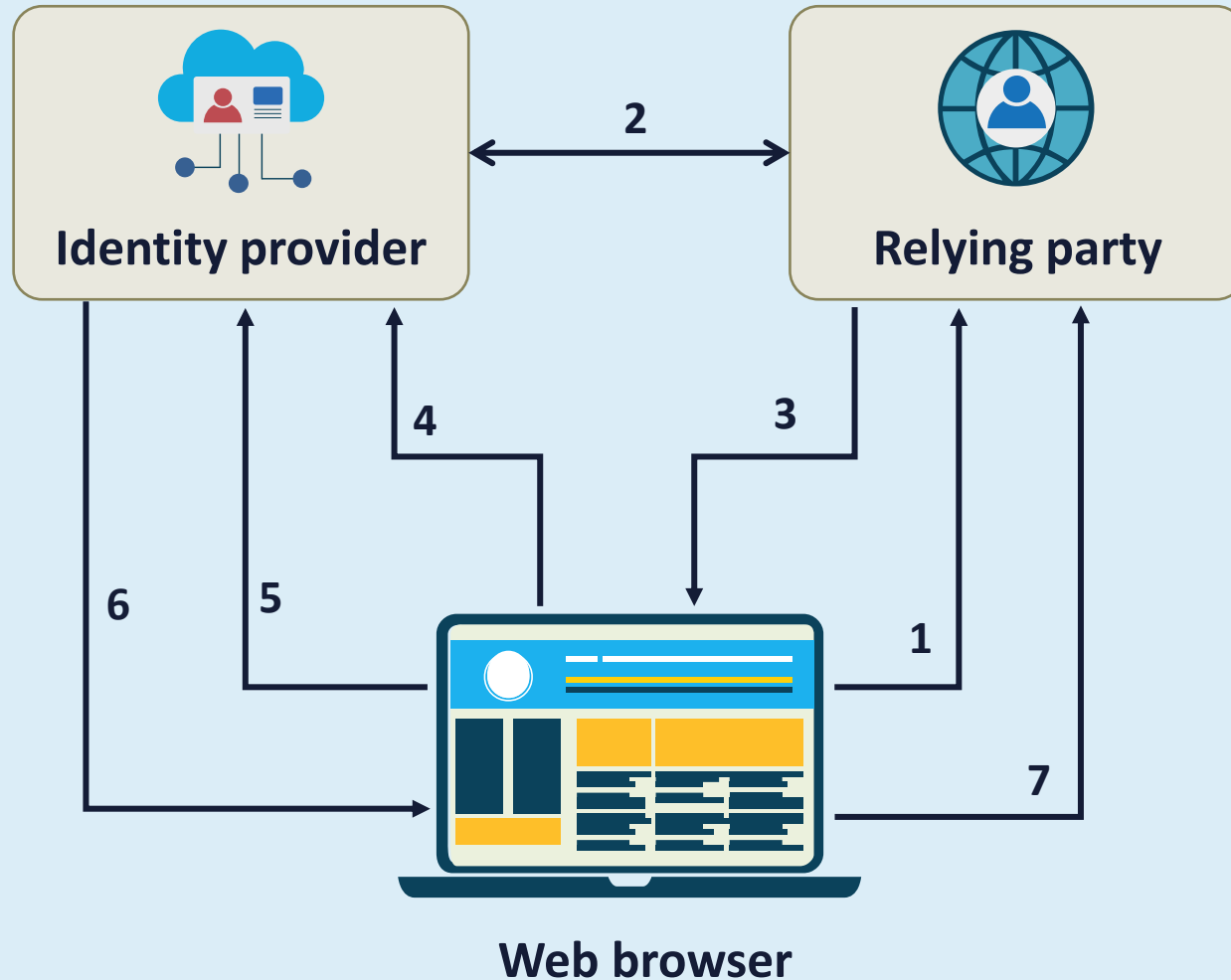
- **OAuth 2.0 is an open authorization framework that allows a third-party application to get limited access to an HTTP service**
- Developers use OAuth to publish and interact with protected data in a safe and secure manner
- Service provider developers can use OAuth to store protected data and give users secure delegated access
- OAuth is designed to work with HTTP and basically allows access tokens to be issued to third-party clients by an authorization server with the approval of the resource owner
- The third party then uses the access token to access the protected resources offered by the resource server

OpenID Connect (OIDC)

Should be used for OAUTH Authentication

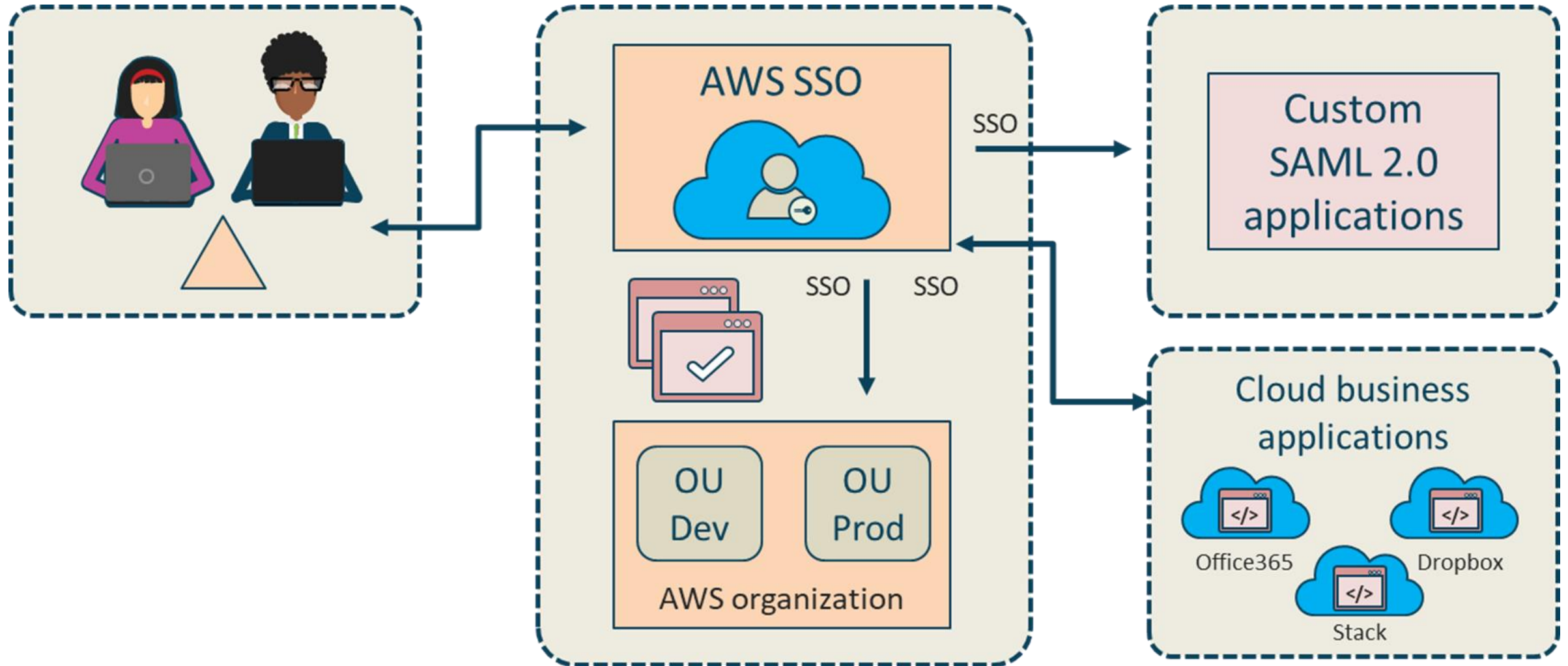
- **OpenID Connect 1.0 is a basic identity layer on top of the OAuth 2.0 protocol**
- It verifies the end-user identity using an authorization server
- It can get basic profile information about the user with an interoperable REST-like methodology
- Supports web-based, mobile, and JavaScript clients
- OpenID is extensible as functionality can be added

OIDC in Action

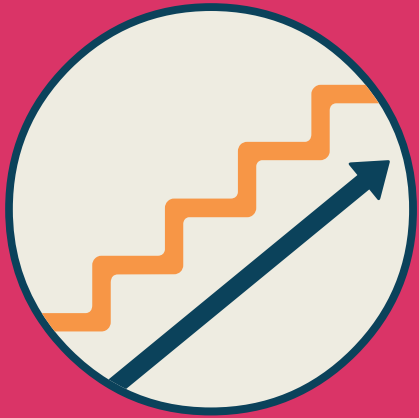


1. User sends their OpenID URL
2. IP and RP set shared secret
3. Browser redirected to get token from provider
4. Request to IP for token for site
5. Login if needed
6. Token returned to browser
7. Token handed to requesting site

Demonstration: AWS IAM and Identity Center (SSO)



Step-Up Authentication



- Ensures that users can access some resources with one set of credentials but will prompt them for more credentials when they request more access
 - Users want seamless SSO access to certain assets, but organizations may want to further verify their identities before they grant access
 - Employees need occasional access to private data that would cause damage if exposed
 - You want to deploy a membership model that limits complete access to your site/service to paying users
 - **Add Knowledge-Based Authentication (KBA) and/or Privileged Identity Management (PIM)**

ENTITLEMENT MATRIX

Entitlement	Super-Admin	Service-1 Admin	Service-2 Admin	Dev	Security-Audit	Security-Admin
Service 1 List	X	X		X	X	X
Service 2 List	X		X	X	X	X
Service 1 Modify Network	X	X		X		X
Service 2 Modify Security Rule	X	X				X
Read Audit Logs	X				X	X

Cloud Telemetry Sources

Management Plane Logs	Service Logs	Resource Logs	Clouds Tools
• Critical source given the importance of protecting the management plane	• API gateway: access logs • Storage: access logs • Network: VPC flow logs • Function/serverless: activity logs • Cloud load balancer: activity logs • Cloud DNS: query logs • Cloud WAF/firewall: activity logs	• Workload: instance, VM logs • Configuration change logs • Cloud function invocation logs • Database transaction logs • Object storage file access logs • Snapshot and image logs (block storage)	• CSPM (Cloud Security Posture Management-SPM) • CASB (Cloud Access Security Broker) • CNAPP (Cloud Native Application Protection Platform) • SSPM (SaaS SPM) • DSPM (Data SPM) • IAM analytics • Cloud detection and response



Cloud Native Application Protection Platform (CNAPP)

- Cloud Security Posture Management (CSPM) encompasses tools and practices that enable organizations to continuously monitor, evaluate, and enhance the security posture of their IaaS/PaaS cloud infrastructure

Cloud Native Application Protection Platform (CNAPP)

- **Cloud Workload Platform Protection (CWPP)** offers a robust suite of tools designed to enhance the security of cloud-based workloads
- These tools can identify vulnerabilities, misconfigurations, and hardening issues within workloads
- A key feature of CWPP is its ability to perform these scans on modern workload types such as containers, Kubernetes, and Functions as a Service



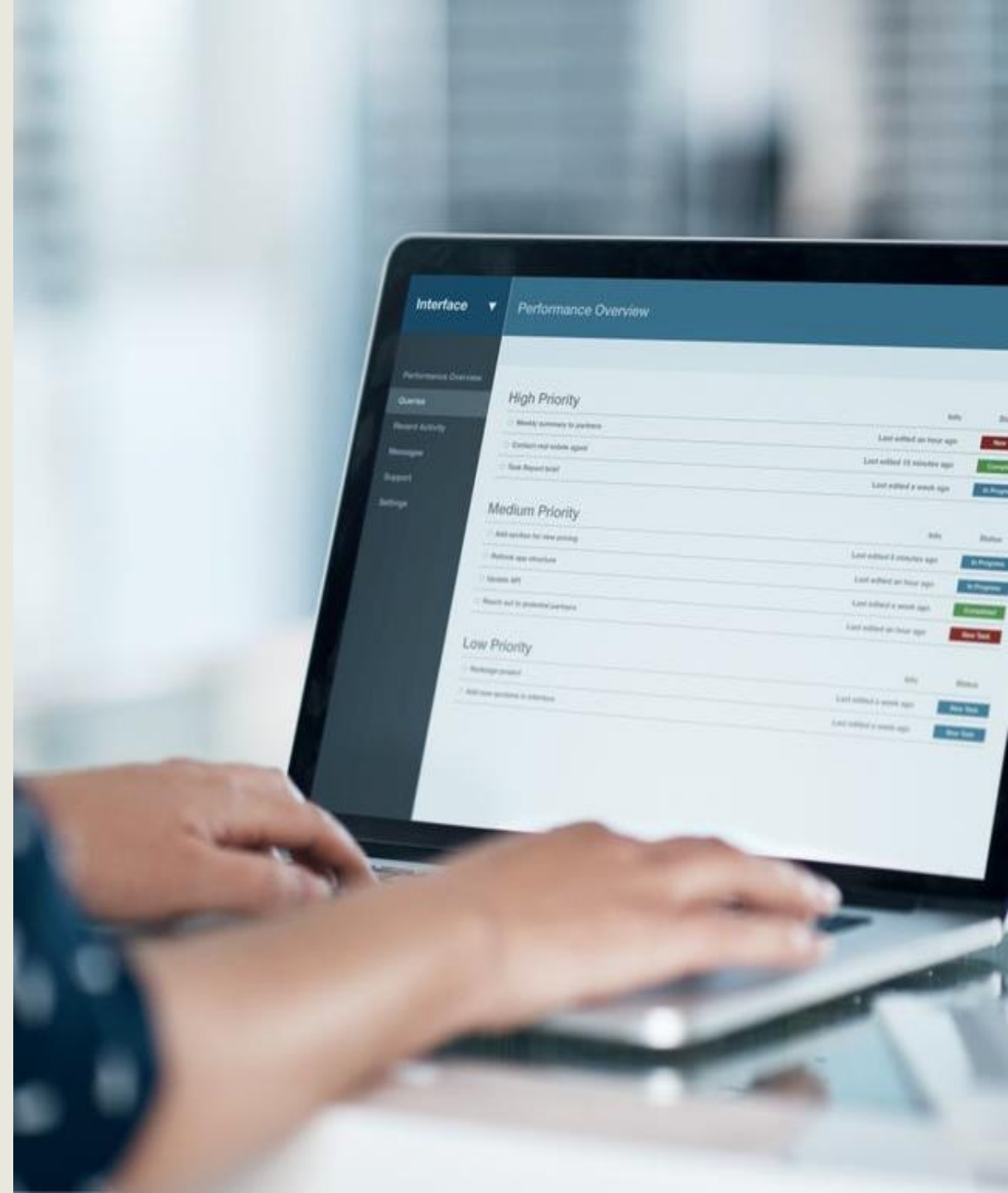


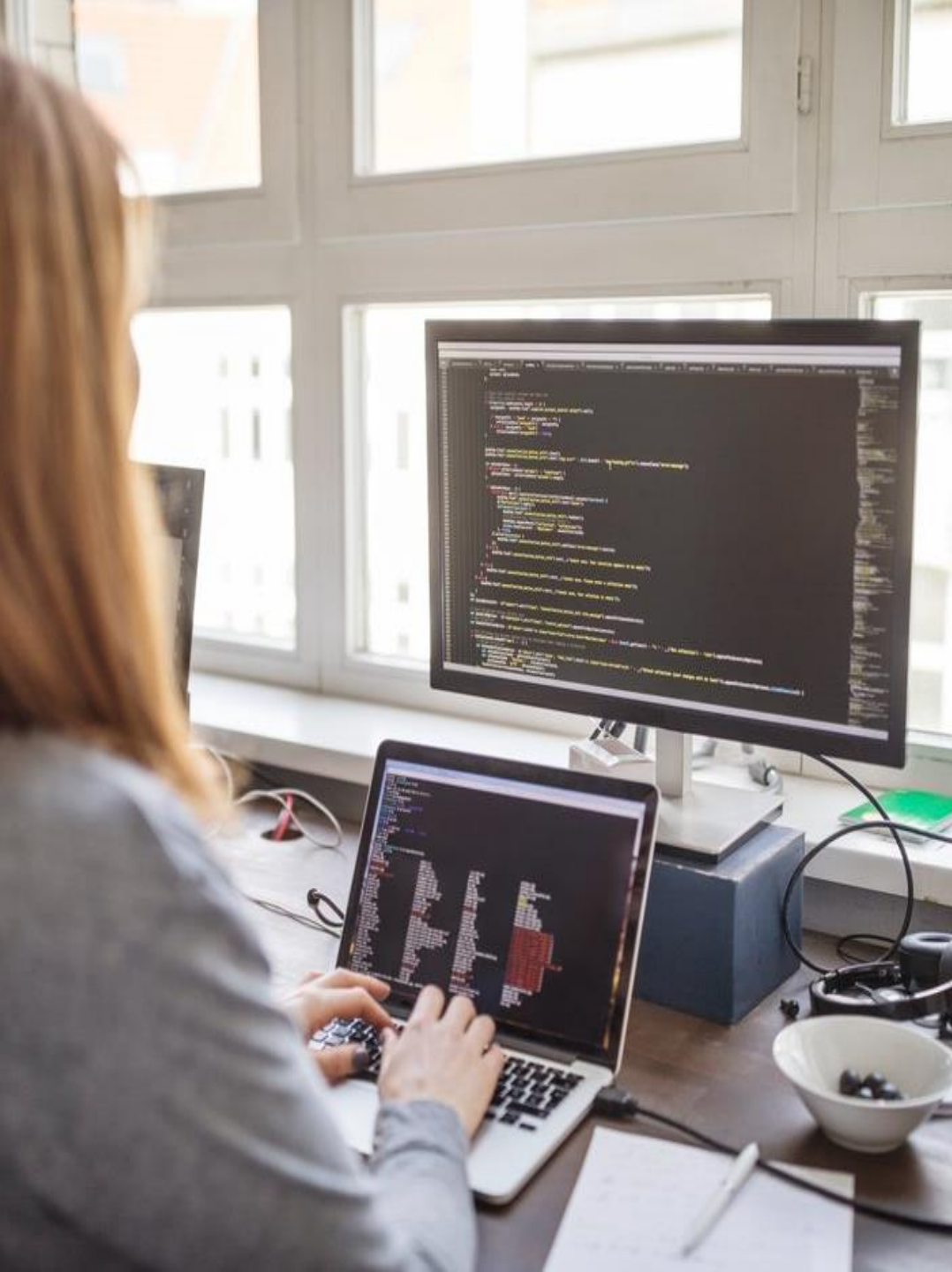
Cloud Native Application Protection Platform (CNAPP)

- **Data Security Posture Management (DSPM)** consists of tools that safeguard sensitive data and ensure compliance with data protection regulations in cloud environments by offering capabilities such as data discovery, classification, and encryption policy enforcement
- **Application Security Posture Management (ASPM)** offers a collaborative platform for security, operations, and developers to detect, prioritize, and remediate vulnerabilities, while implementing security policies throughout the application development and deployment phases

Cloud Native Application Protection Platform

- **Cloud Infrastructure Entitlement Management (CIEM)** tools provide comprehensive visibility and control over cloud infrastructure identities
- They assist organizations in enforcing the principle of least privilege by ensuring that users, applications, and services have only the necessary access to perform their functions





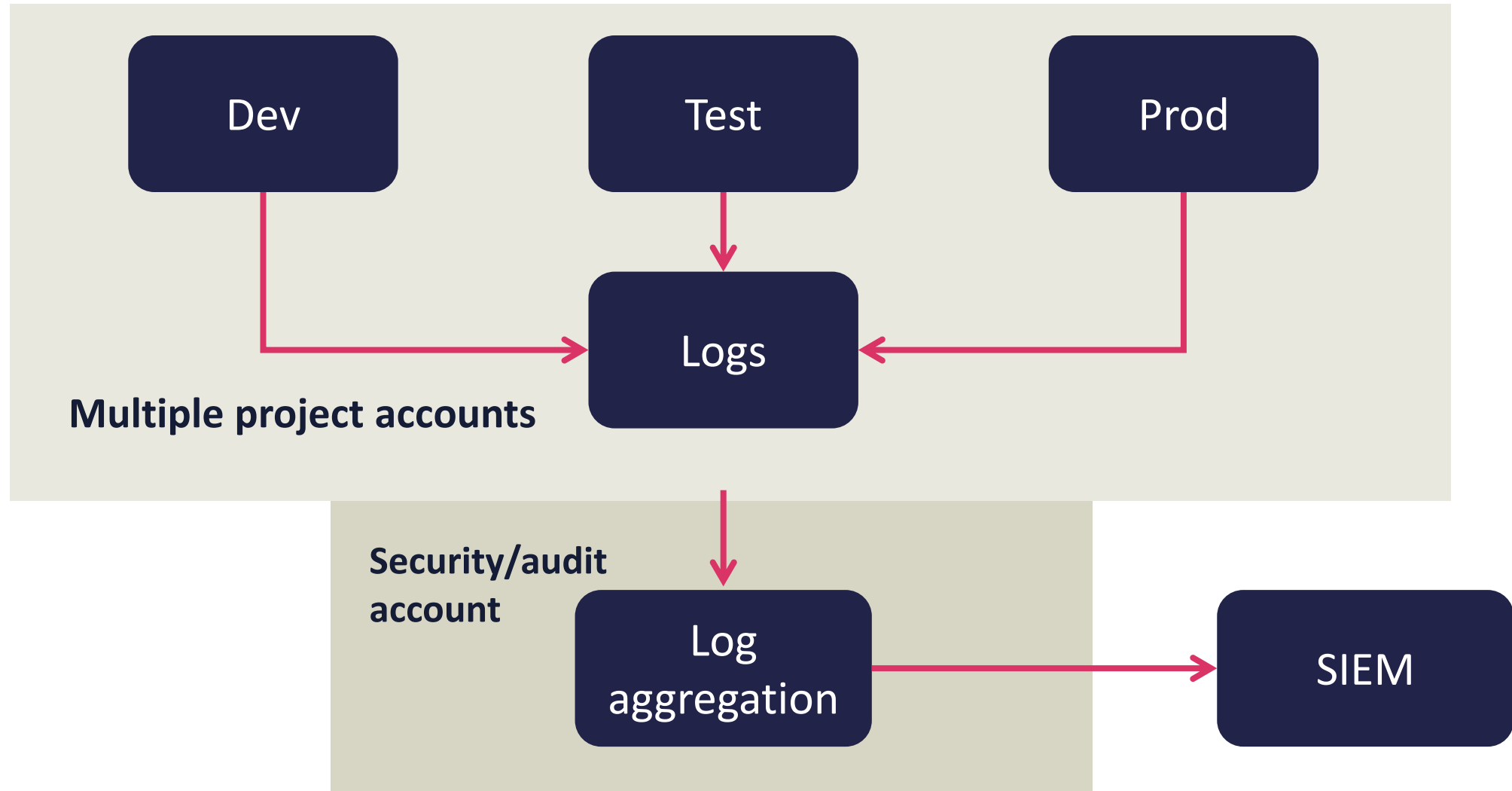
CNAPP

- **Cloud Detection and Response (CDR)** tools are designed to identify and address security threats and incidents within cloud environments
- By utilizing advanced analytics, threat intelligence, and potentially machine learning algorithms, these tools can detect suspicious activities, anomalous behavior, and indicators of compromise
- CDR tools enable swift incident detection, investigation, and response, thereby helping to mitigate the impact of security breaches and unauthorized access attempts in the cloud

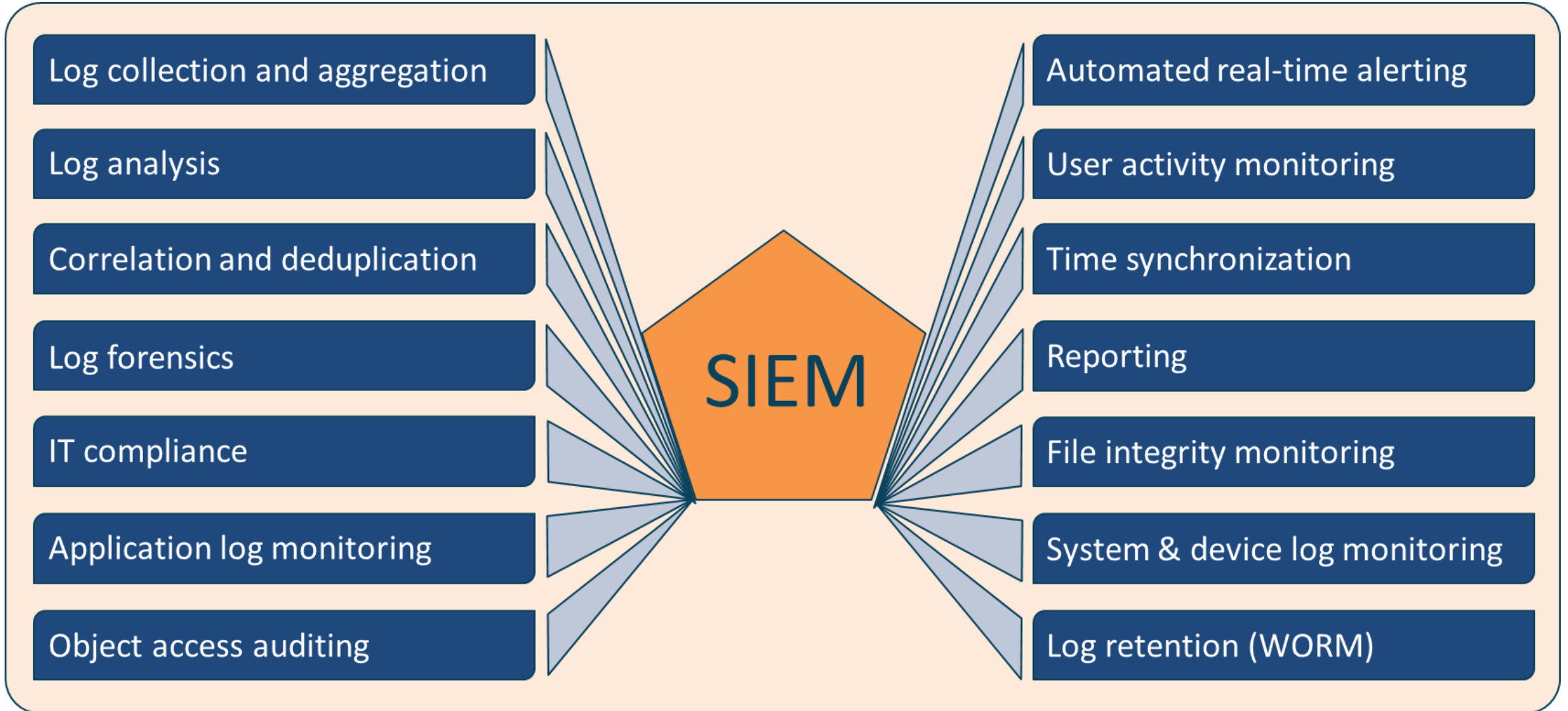
- **SaaS Security Posture Management (SSPM)** allows organizations to oversee and monitor SaaS applications, ensuring they are properly configured and entitled
- These tools provide centralized visibility into security controls, configurations, and compliance status across various SaaS applications
- SSPM tools assist in evaluating the effectiveness of SaaS security, enforcing security policies, and ensuring compliance with contractual obligations and regulatory requirements



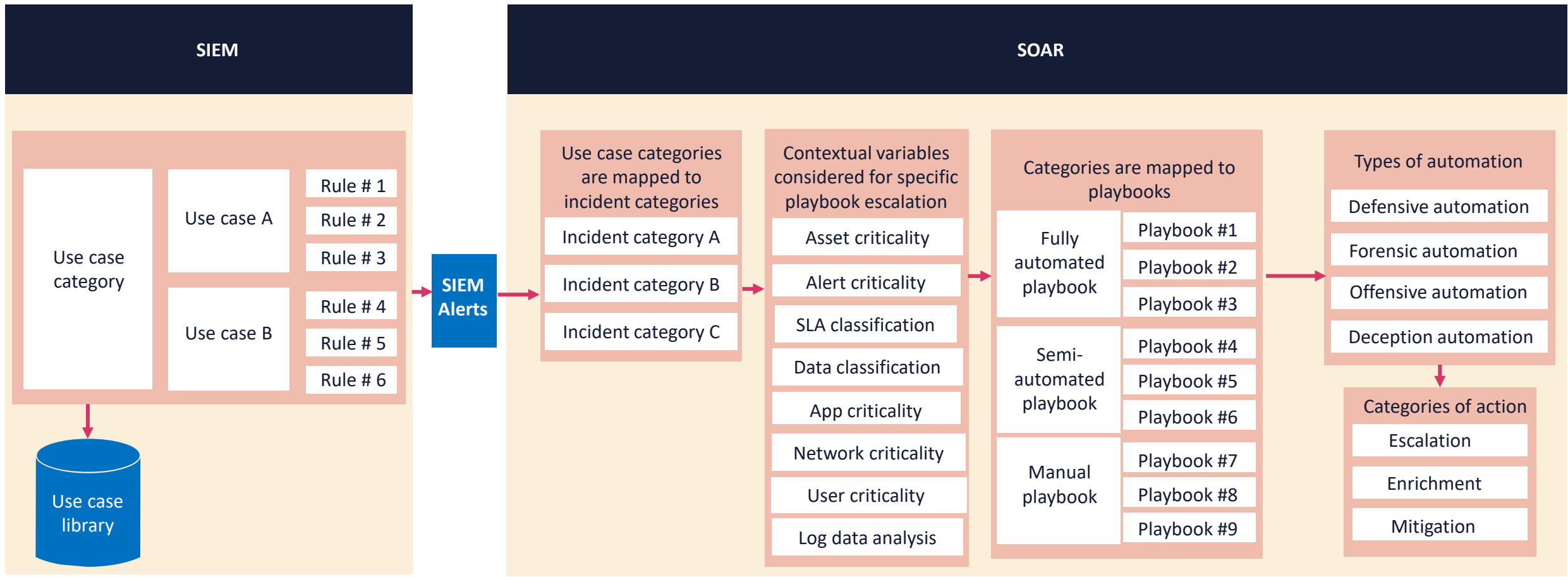
Cascading Log Architecture



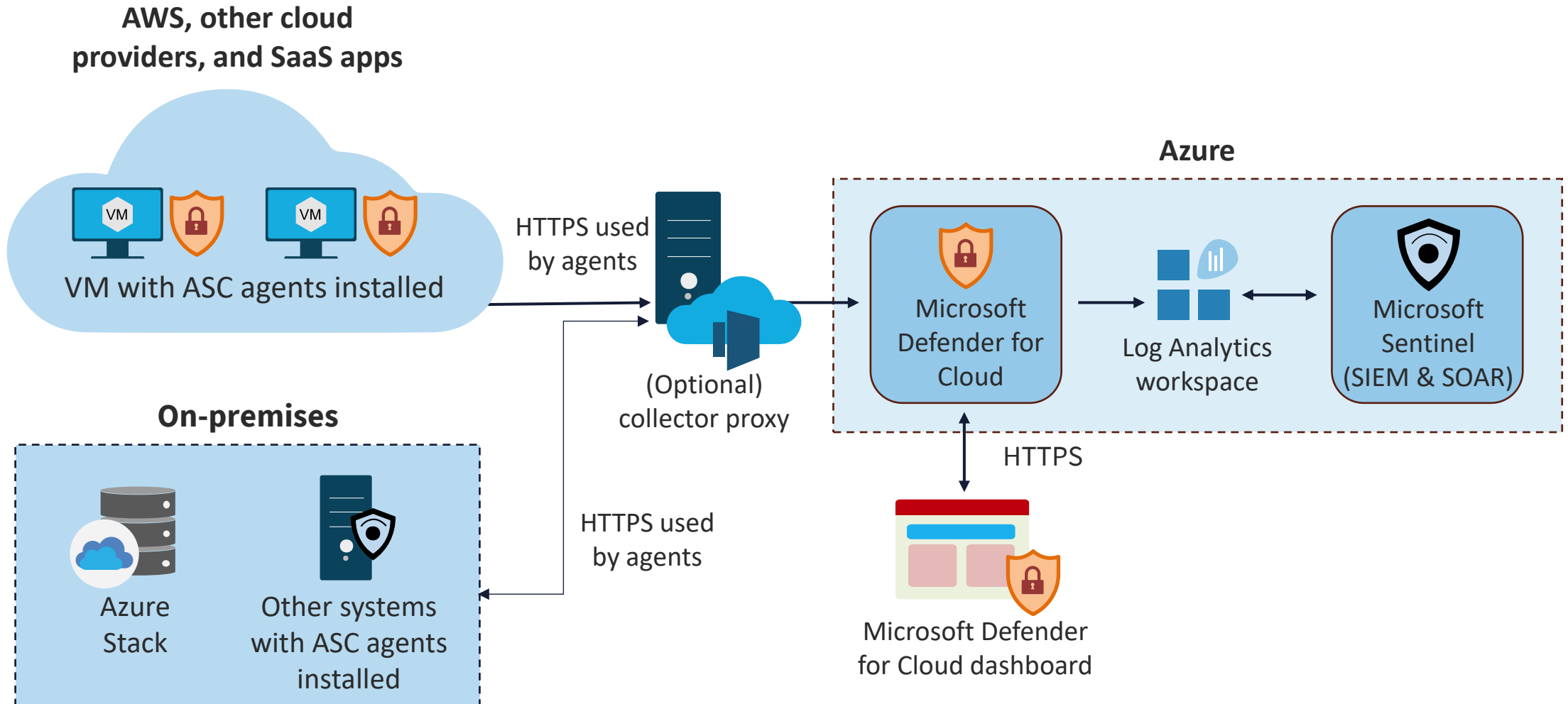
Security Information and Event Monitoring



Collecting Security Data with SIEM and SOAR



Hybrid Cloud Analysis with Azure Sentinel



AI for Security Monitoring

- **Anomaly Detection:** This process utilizes machine learning to detect abnormal patterns in data traffic and user behavior, enabling quicker and more precise identification of potential security threats compared to traditional methods
- **Threat Intelligence and Threat Hunting:** This involves leveraging AI to analyze large amounts of data from various sources to recognize emerging threats and generate real-time alerts



AI for Security Monitoring

- **Automated Responses:** This entails utilizing AI-driven automation to swiftly address security incidents, thereby minimizing the time between threat detection and mitigation
- **Assisting Analysts:** This process involves enhancing logs, simulating attacks, patching vulnerabilities, and lowering the overall overhead on security teams

